

Course-End Project

Conducting Vulnerability Assessment and Penetration Testing on a Simulated Web Application Environment

Objective

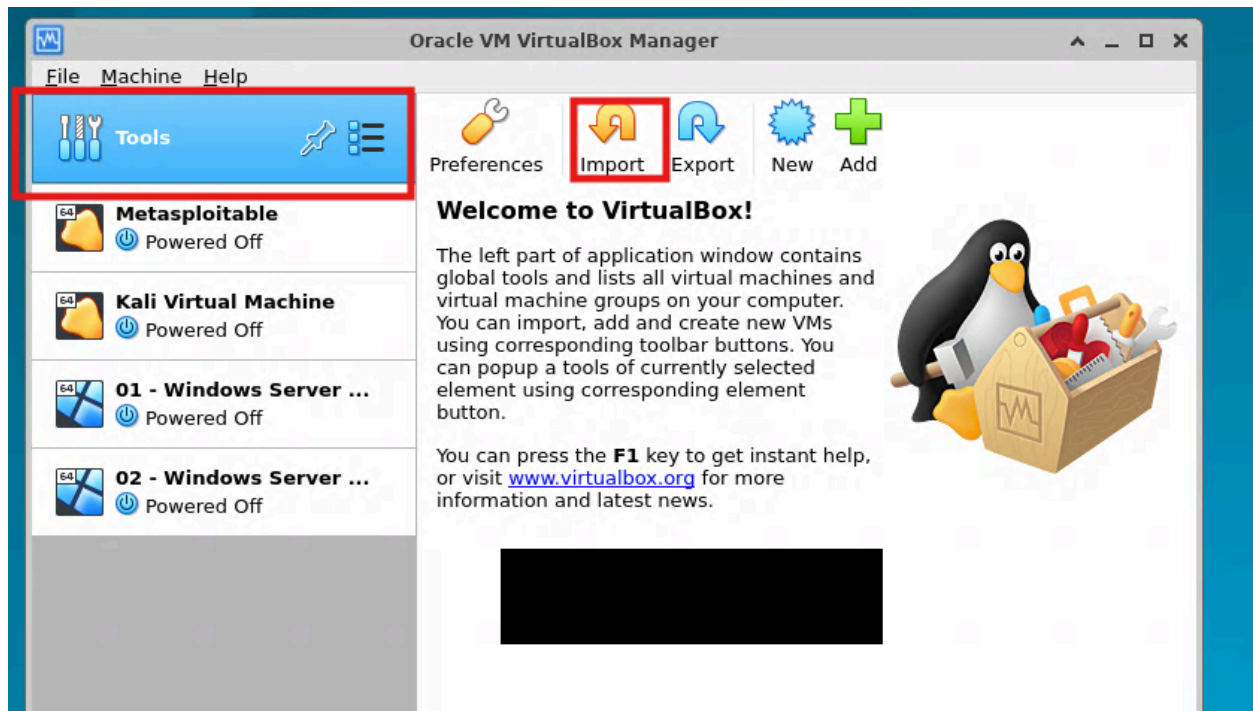
To gain hands-on experience in web application penetration testing by identifying vulnerabilities within a simulated product website. Use open-source tools and manual techniques to uncover hidden secrets (flags) planted by developers. Conduct vulnerability assessments to enhance the security of web applications. Simulate real-world hacking scenarios to address potential misconfigurations or overlooked weaknesses.

Tasks

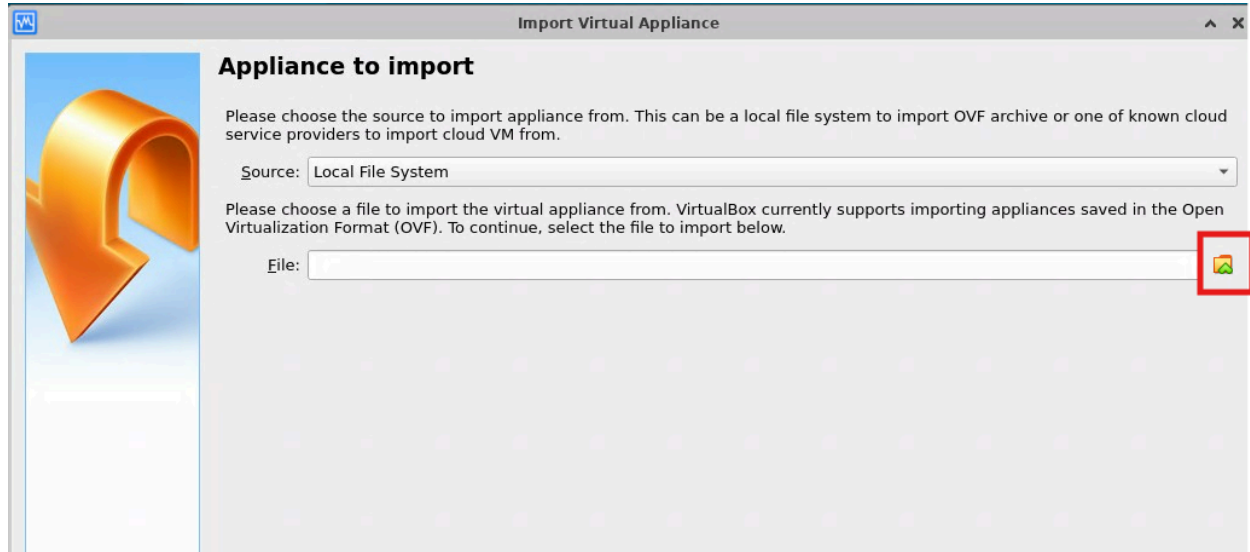
1. Deployment of Appliance [VulnVMa.ova](#)
2. Configure the machine's network
3. Perform reconnaissance on the CTF Box machine IP
4. Vulnerability Assessment
5. Reporting

Task 1: Deployment of Appliance VulnVMa.ova

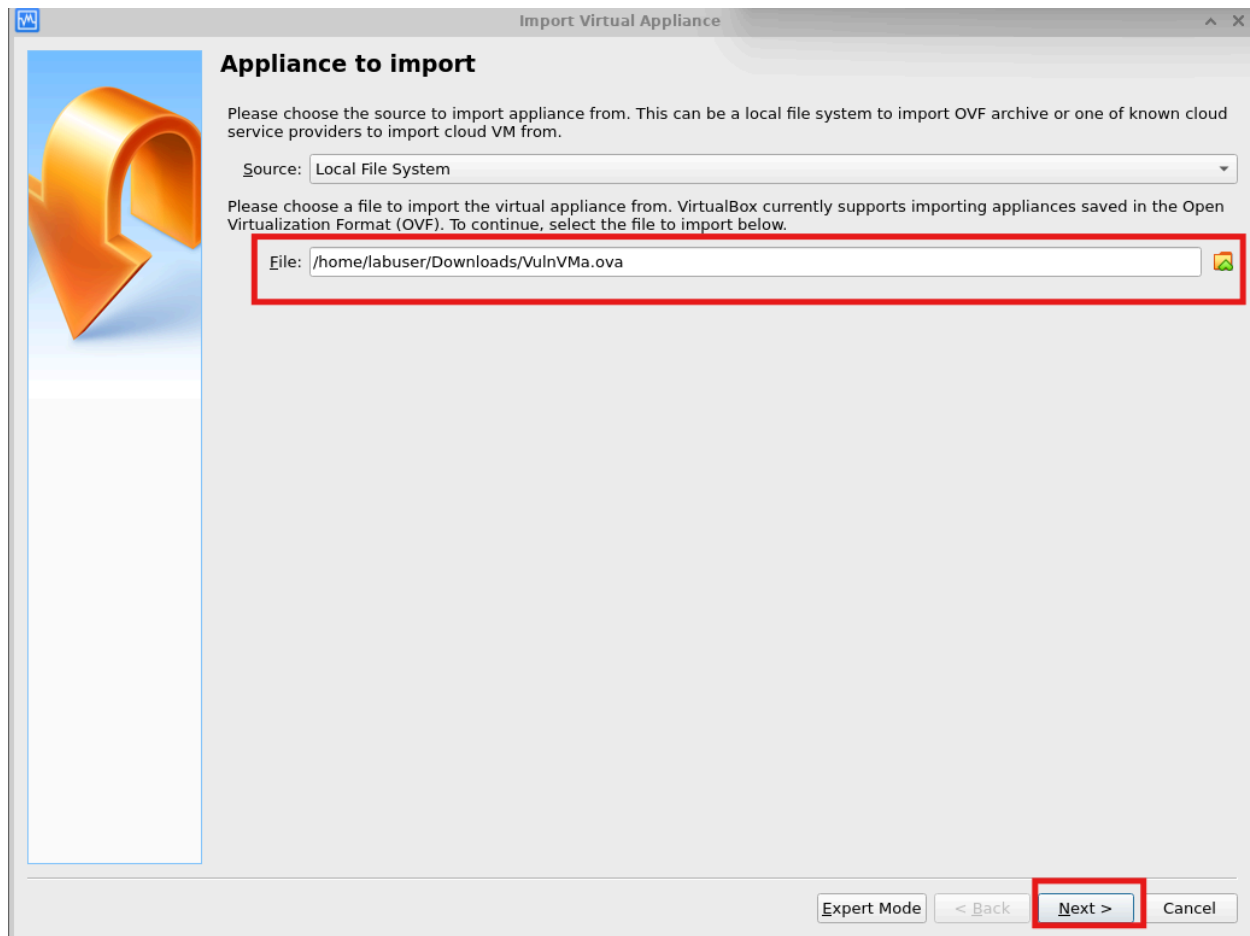
- 1.1 Open the Oracle VirtualBox and select the Tools, then click on Import.



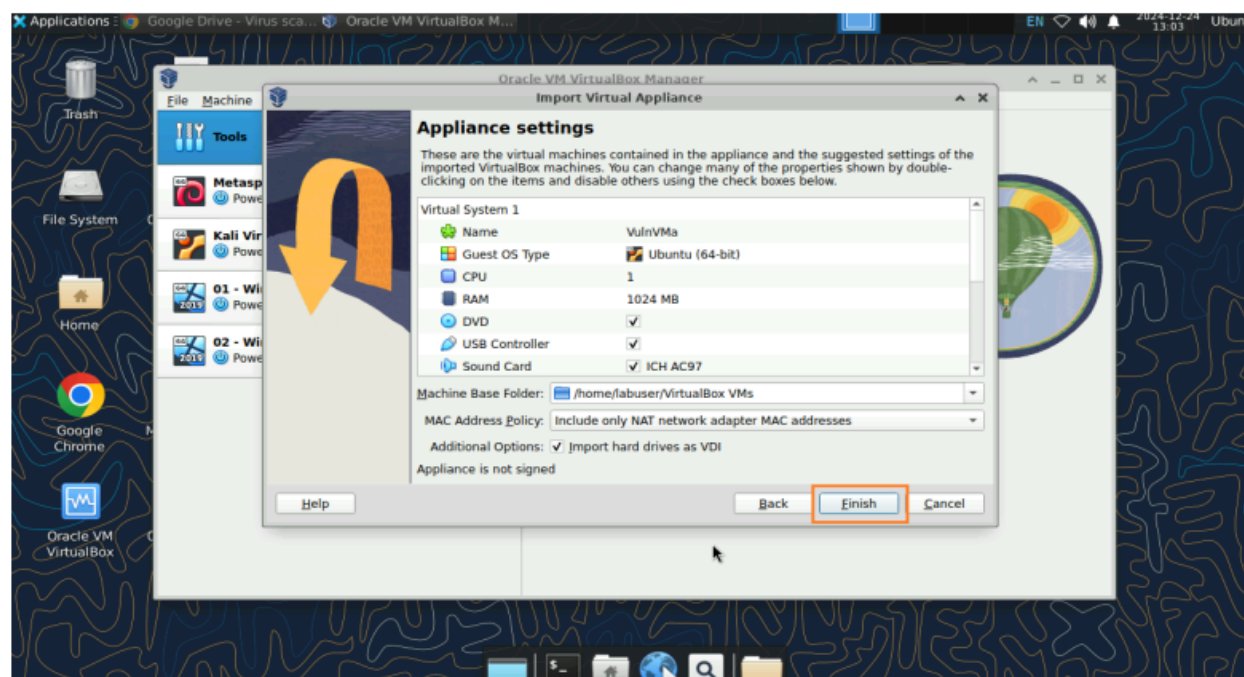
1.2 Click on Select the file.



1.3 After selecting the vulnvma.ova file click on Next.

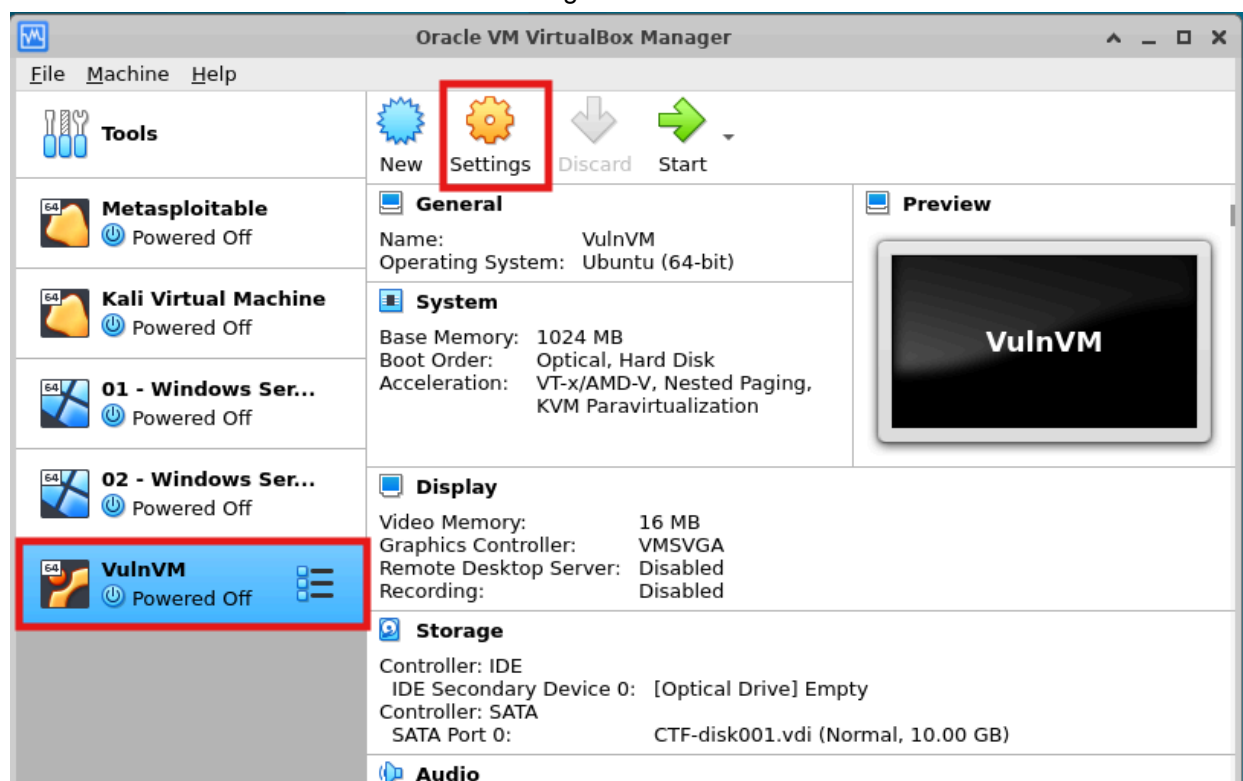


1.4 Click on Finish

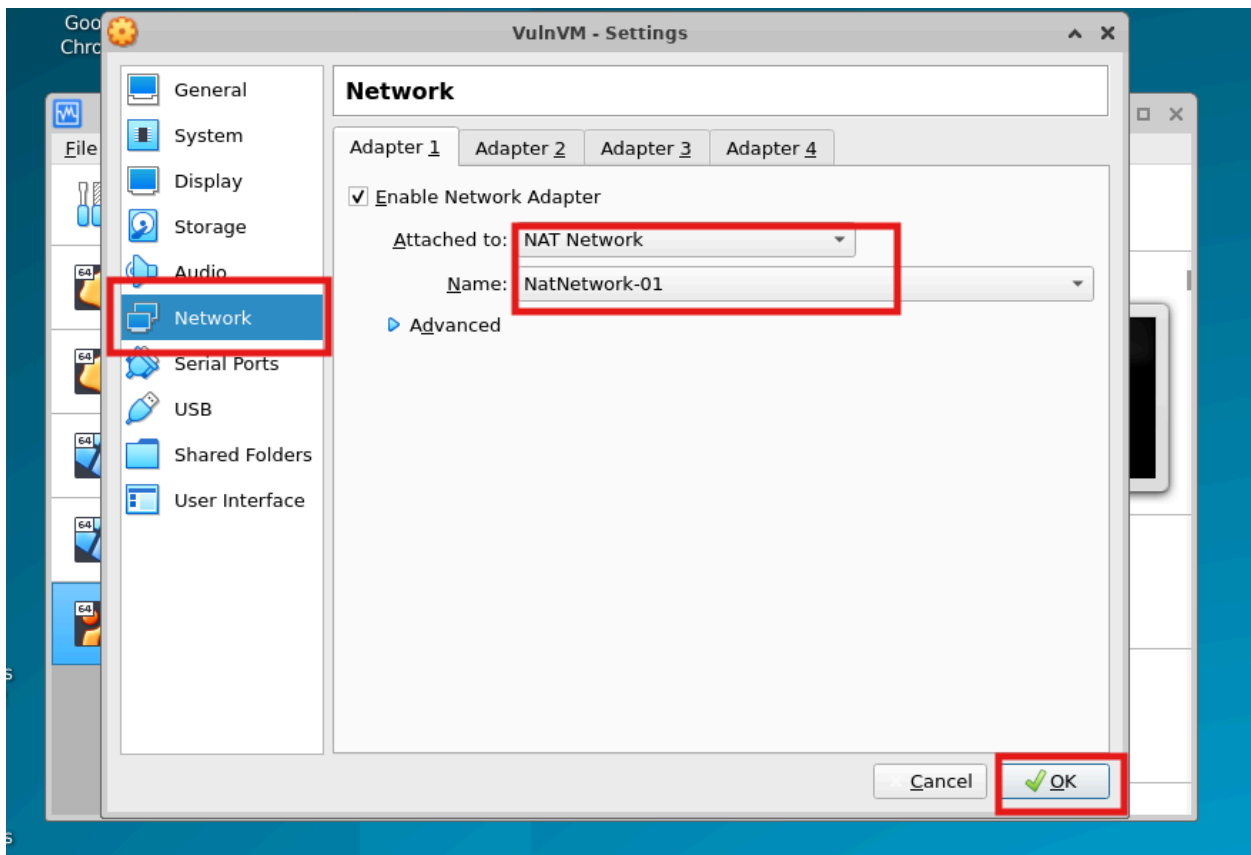


Task 2: Configure the machine's network

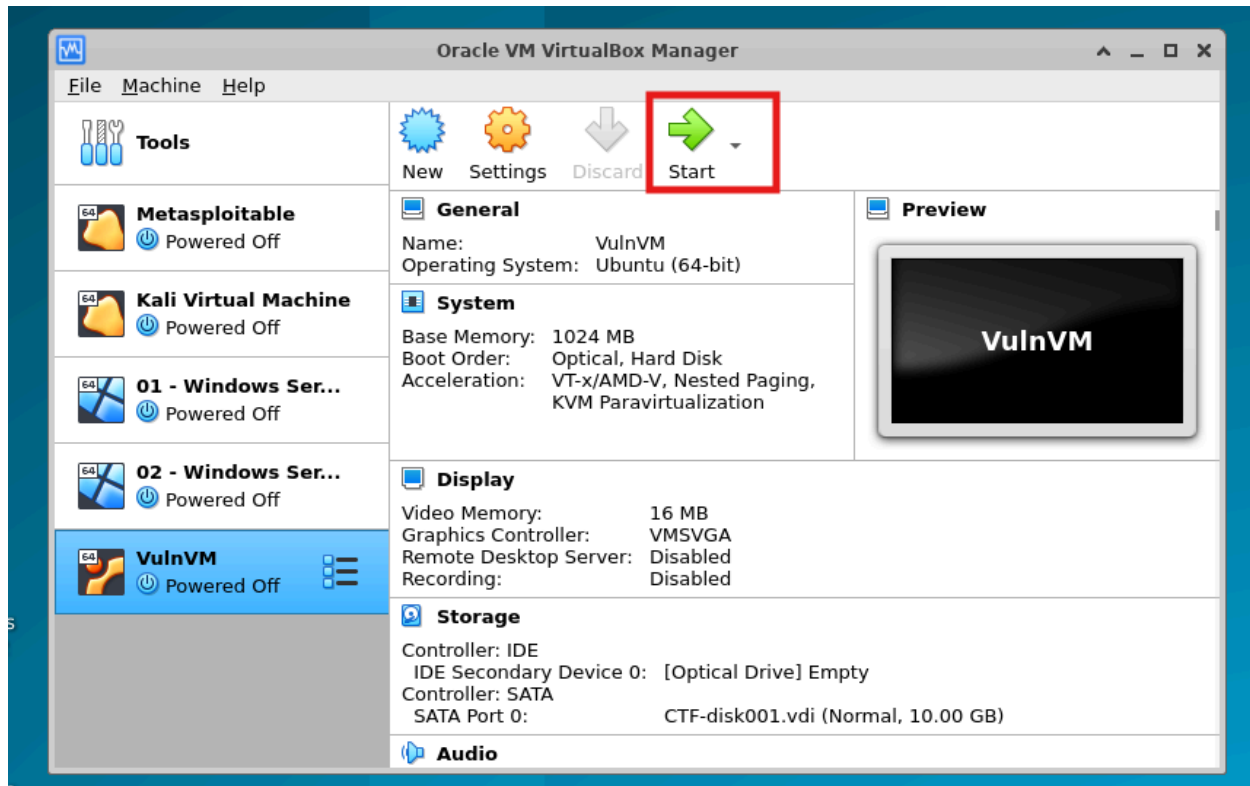
2.1 Now select the VulnVMa and click on Settings.



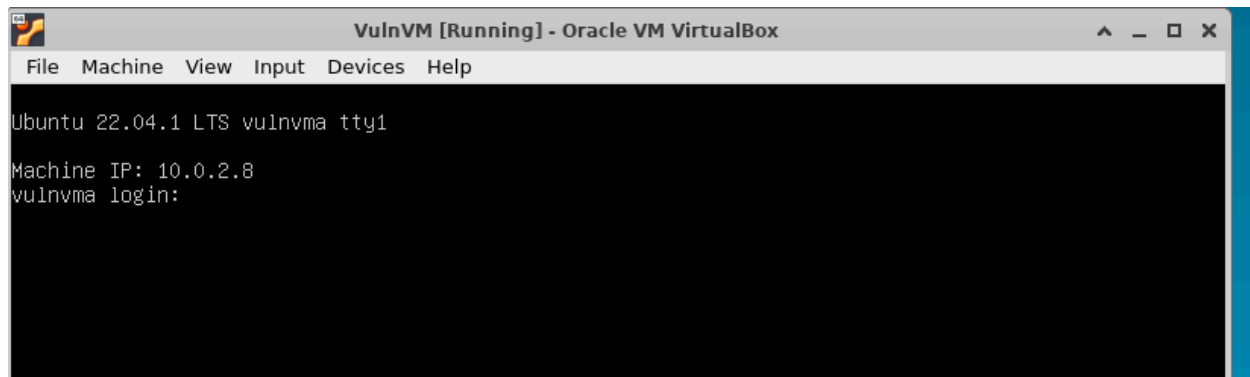
2.2 Navigate to Network and select the NatNetwork-01 then click on ok.



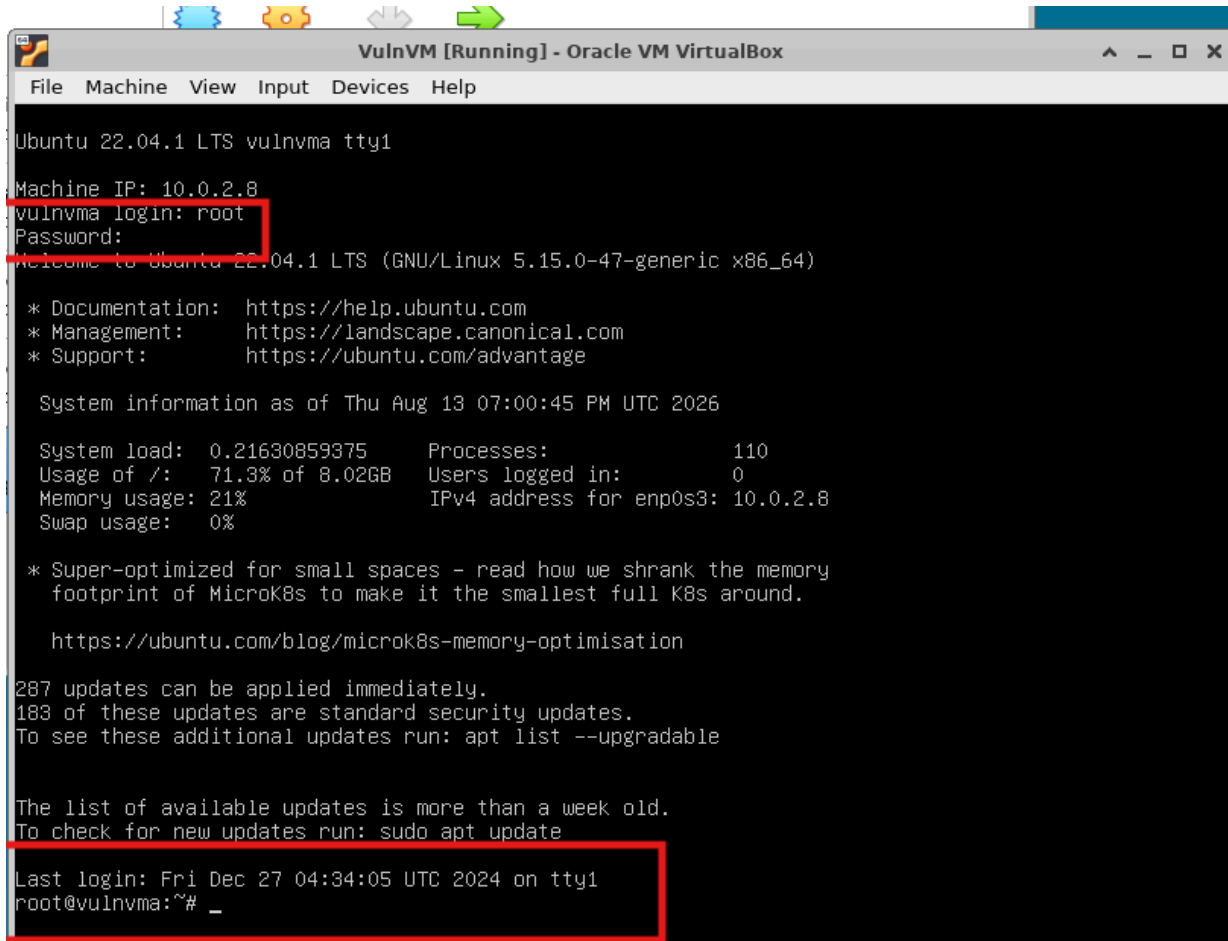
2.3 Click on Start.



2.4 Now we can see the IP of VulnVMa. The IP of VulnVMa is 10.0.5.4 \



2.5 Use the username (root) and password (toor) to login.



```
Ubuntu 22.04.1 LTS vulnvma tty1
Machine IP: 10.0.2.8
vulnvma login: root
Password:
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-47-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Thu Aug 13 07:00:45 PM UTC 2026

System load: 0.21630859375   Processes:            110
Usage of /:  71.3% of 8.02GB   Users logged in:      0
Memory usage: 21%           IPv4 address for enp0s3: 10.0.2.8
Swap usage:  0%

 * Super-optimized for small spaces - read how we shrank the memory
   footprint of MicroK8s to make it the smallest full K8s around.

   https://ubuntu.com/blog/microk8s-memory-optimisation

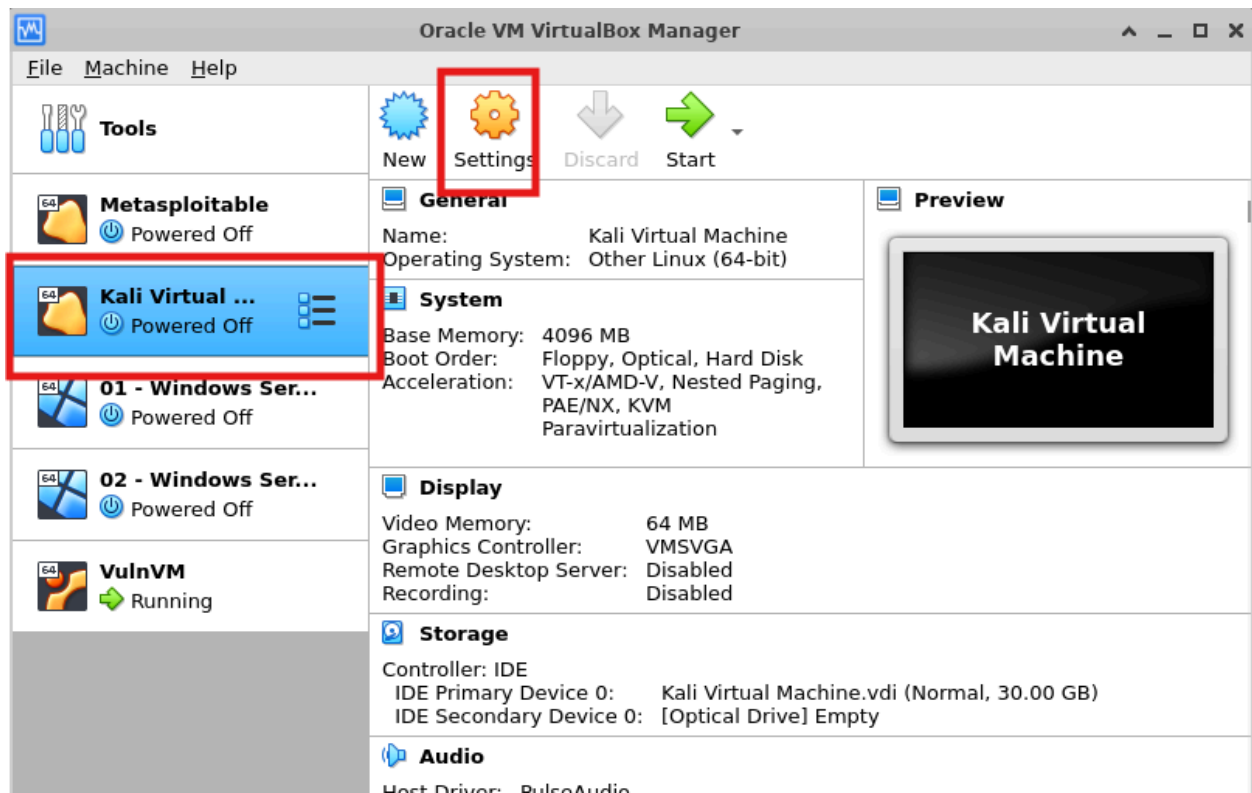
287 updates can be applied immediately.
183 of these updates are standard security updates.
To see these additional updates run: apt list --upgradable

The list of available updates is more than a week old.
To check for new updates run: sudo apt update

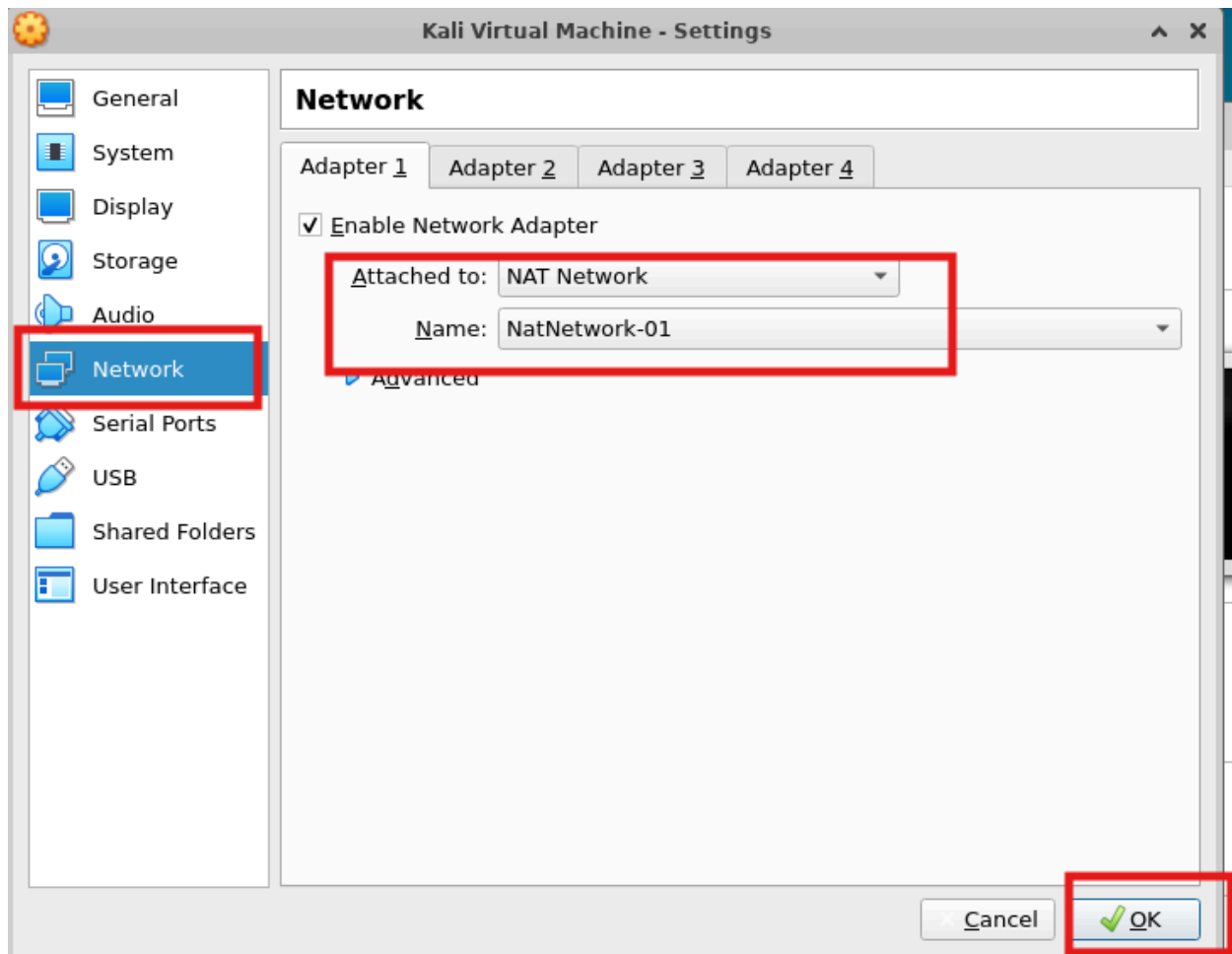
Last login: Fri Dec 27 04:34:05 UTC 2024 on tty1
root@vulnvma:~# _
```

Task 3: Perform reconnaissance on the CTF Box machine IP

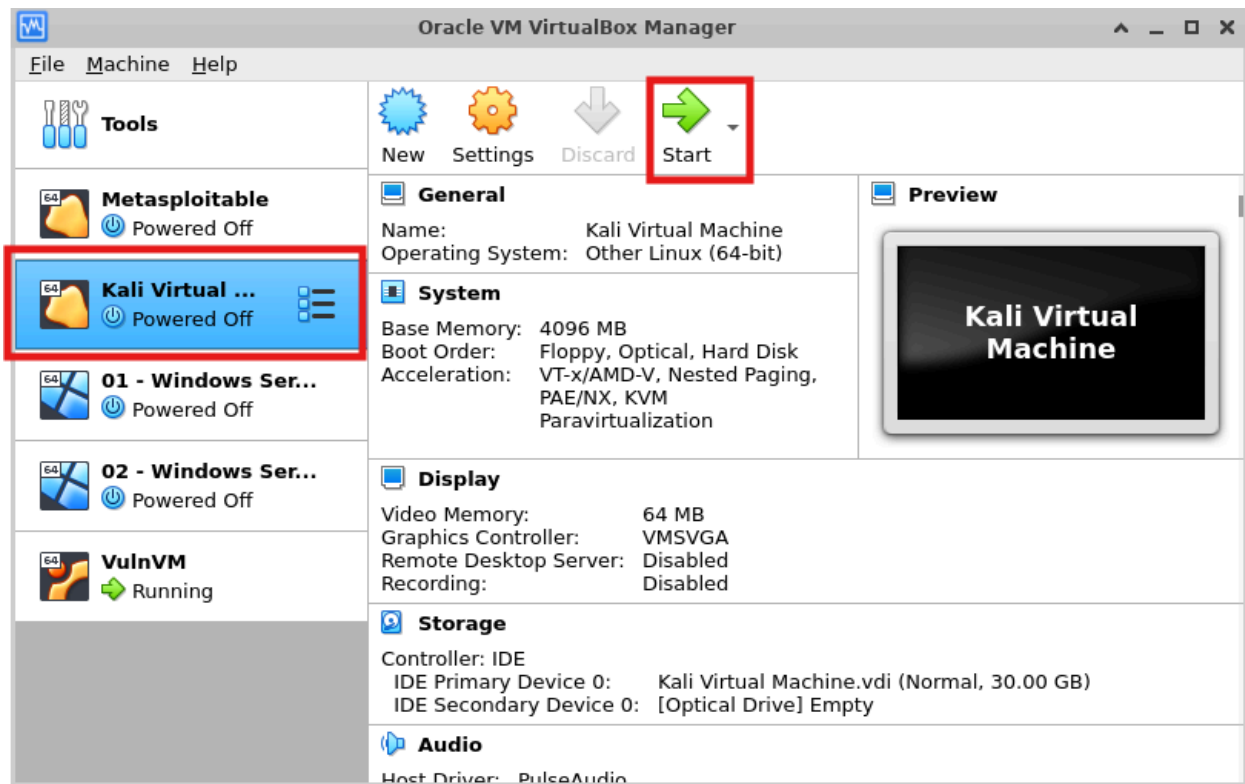
3.1 Select the Kali Linux and click on Settings.



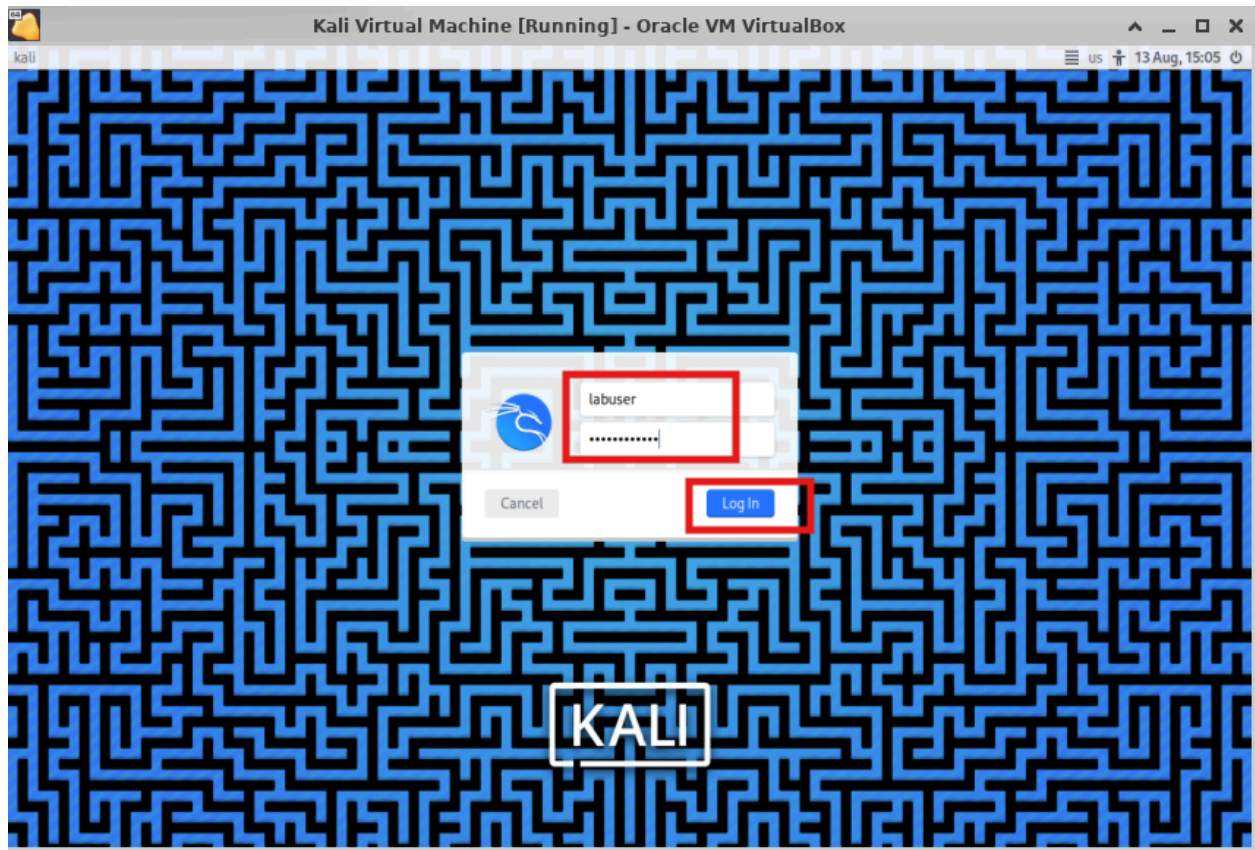
3.2 Navigate Network and select the NatNetwork-01 then click on ok.



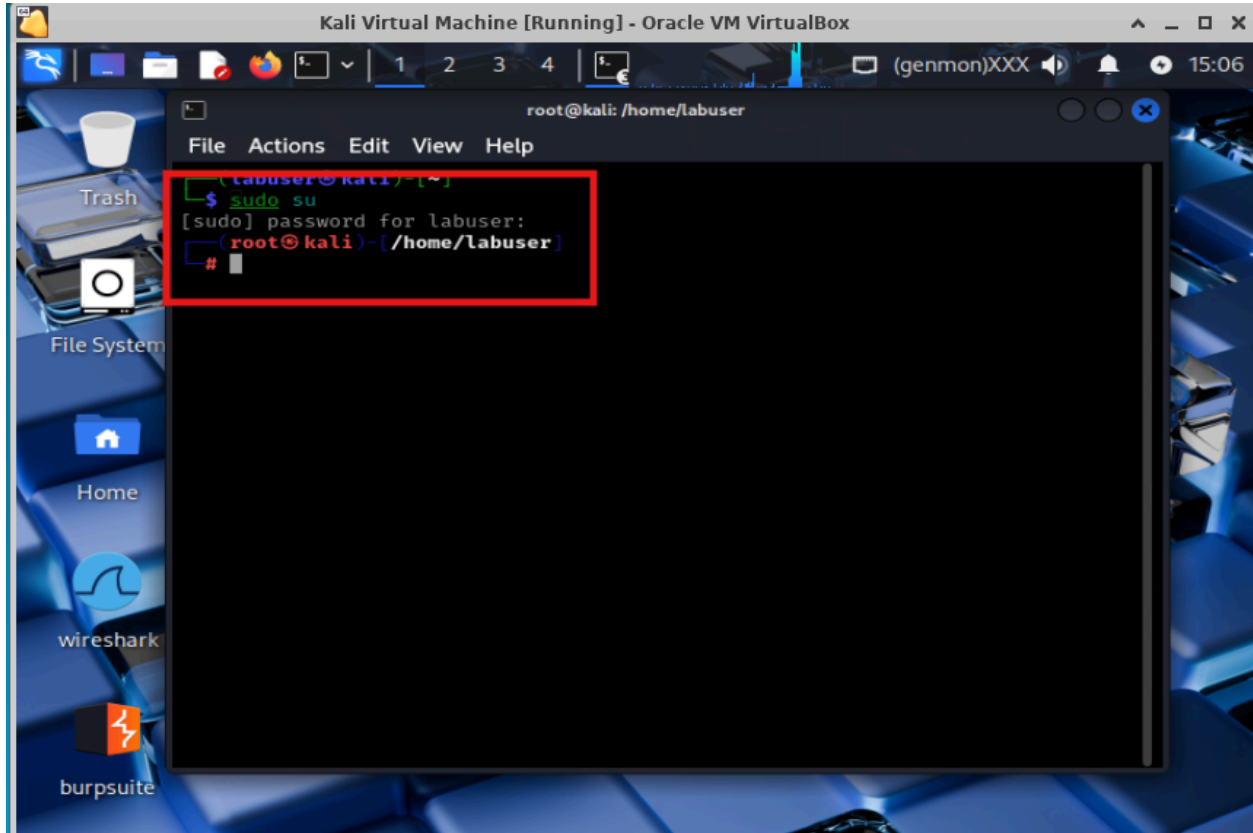
3.3 Click on Start.



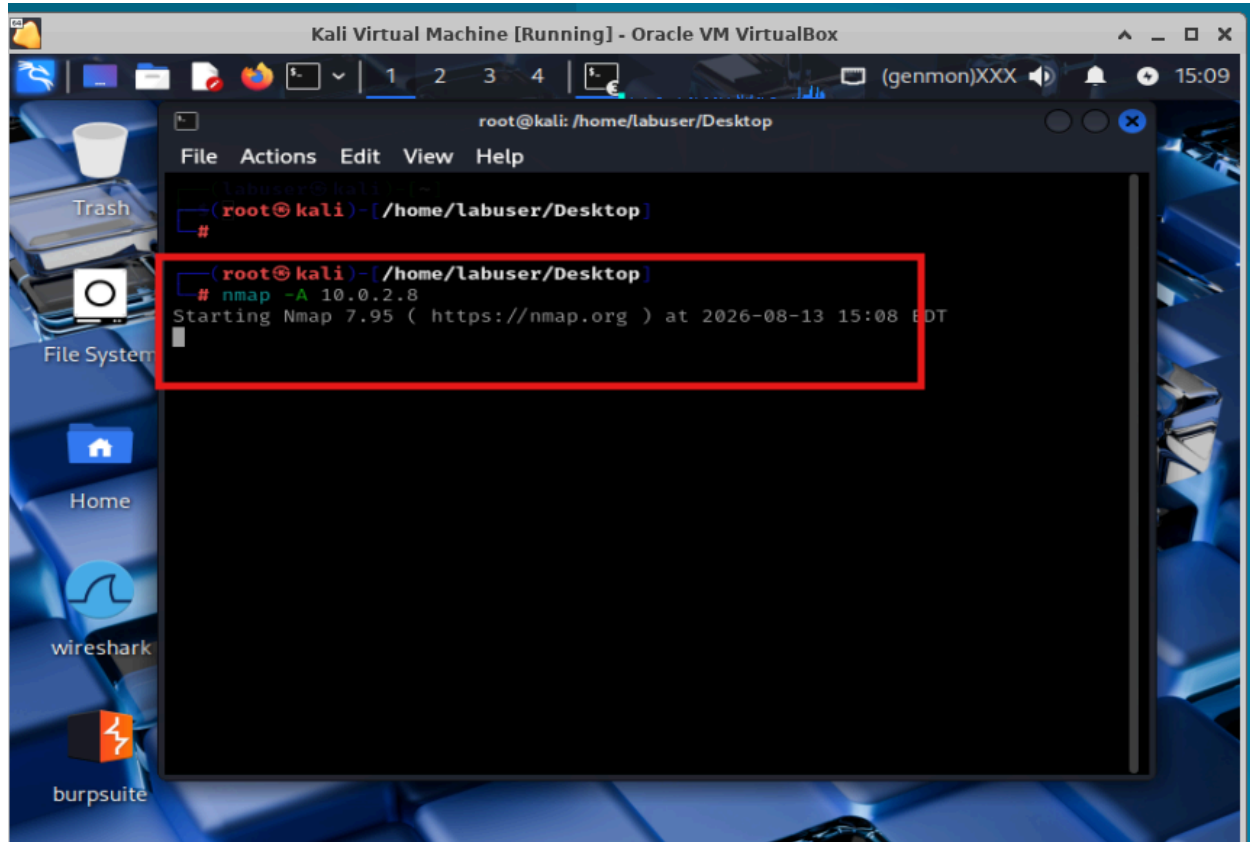
3.4 Use the username (labuser) and password (Password.1!!) to login.



3.5 Switch on the Kali-Linux Machine. Open a terminal and use command: “sudo su”. Then enter the password. This will change the terminal into root.



3.6 Then use command: "nmap -A 10.0.2.8". This will start performing Aggressive scanning of the CTF Machine [IP: 10.0.2.8]

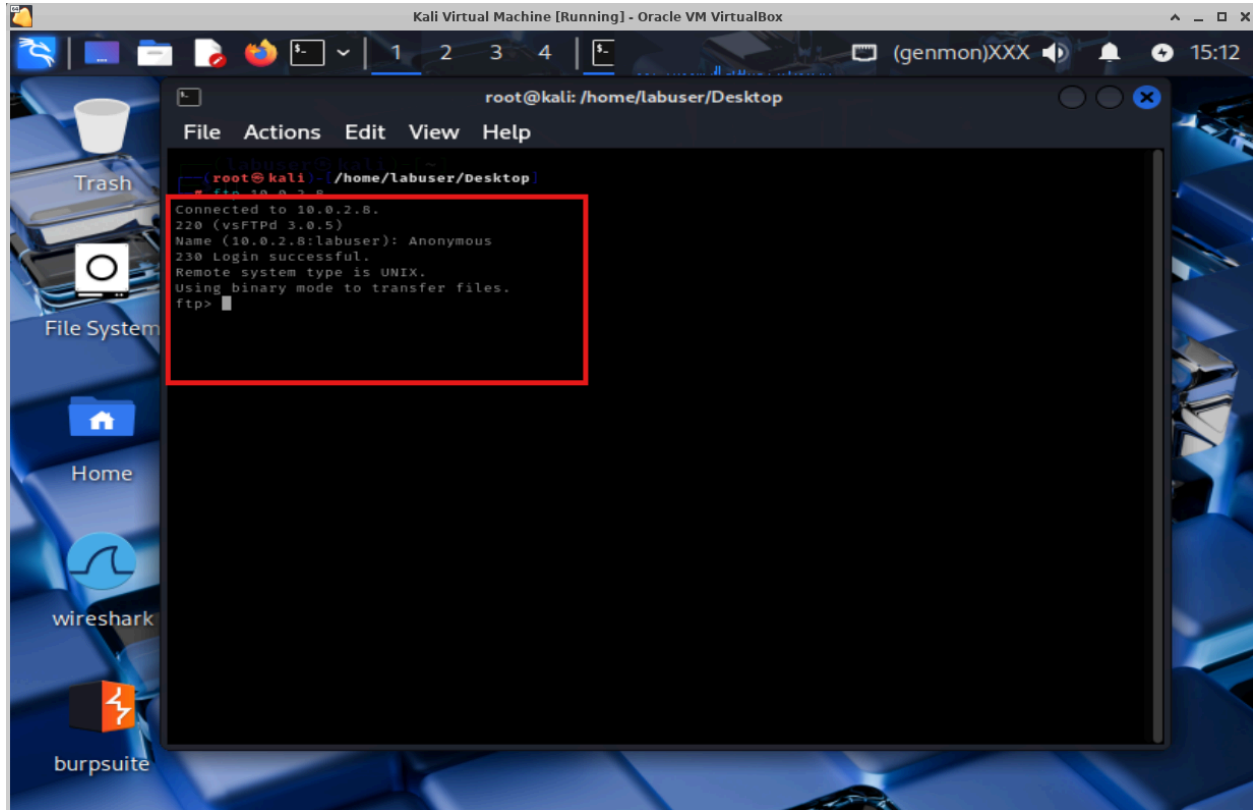


3.7 We find some ports are open. We will try exploiting them.

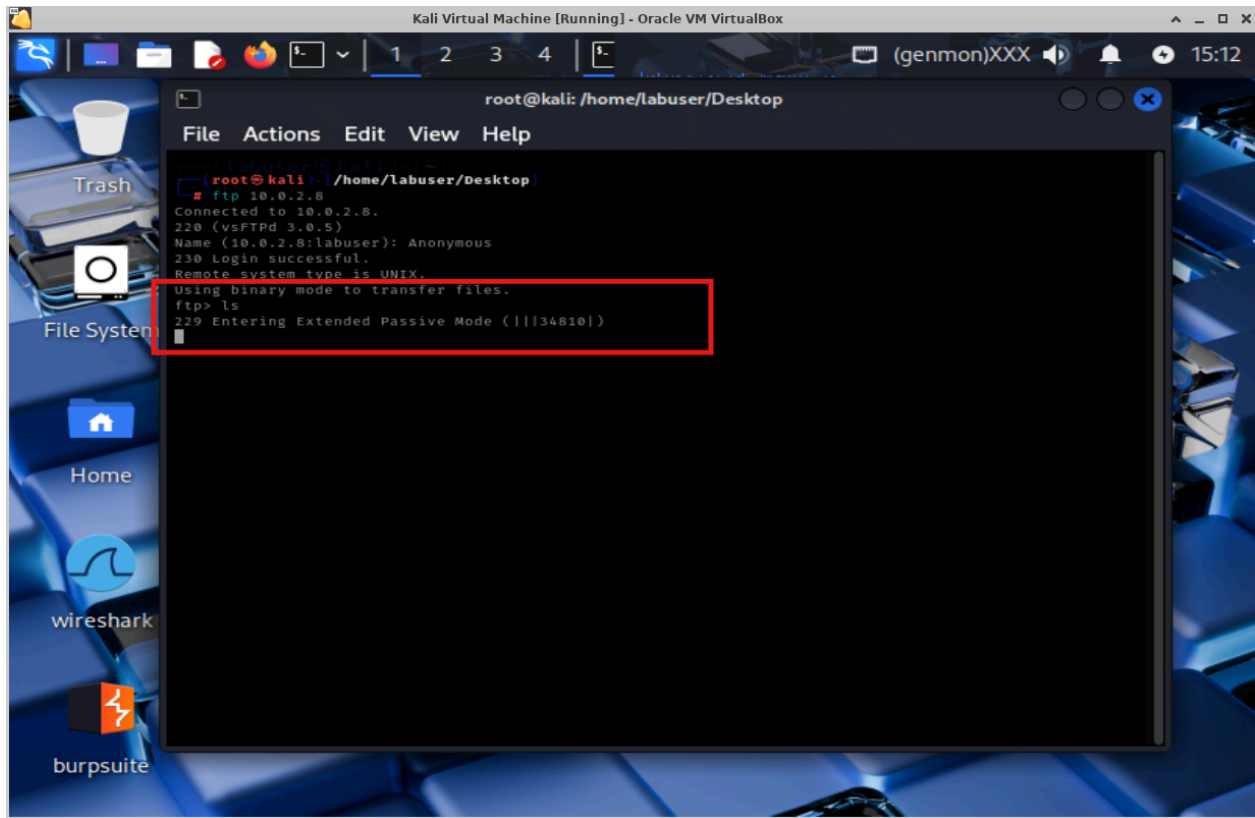
```
root@kali: /home/labuser/Desktop
File Actions Edit View Help
root@kali: /home/labuser/Desktop
# nmap -A 10.0.2.8
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-13 15:08 EDT
Nmap scan report for 10.0.2.8
Host is up (0.00049s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
20/tcp    closed ftp-data
21/tcp    open  ftp      vsftpd 3.0.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: TIMEOUT
|_ ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to ::ffff:10.0.2.5
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 1
|     vsFTPD 3.0.5 - secure, fast, stable
|_ End of status
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 21:ed:bf:e2:7c:62:18:0d:5c:94:23:6f:5b:10:5d:12 (ECDSA)
|_ 256 17:d8:f4:63:63:b2:fe:38:7b:d0:12:b0:71:1a:ab:70 (ED25519)
80/tcp    open  http     Apache httpd 2.4.52 ((Ubuntu))
|_ http-robots.txt: 1 disallowed entry
|_/_
|_ http-title: Travel Blog
|_ http-server-header: Apache/2.4.52 (Ubuntu)
443/tcp   closed https
8080/tcp  closed http-proxy
```

Task 4: Vulnerability Assessment

4.1 Now use command: "ftp 10.0.2.8" to connect. Use credentials as Anonymous to try logging in if Anonymous login is allowed.



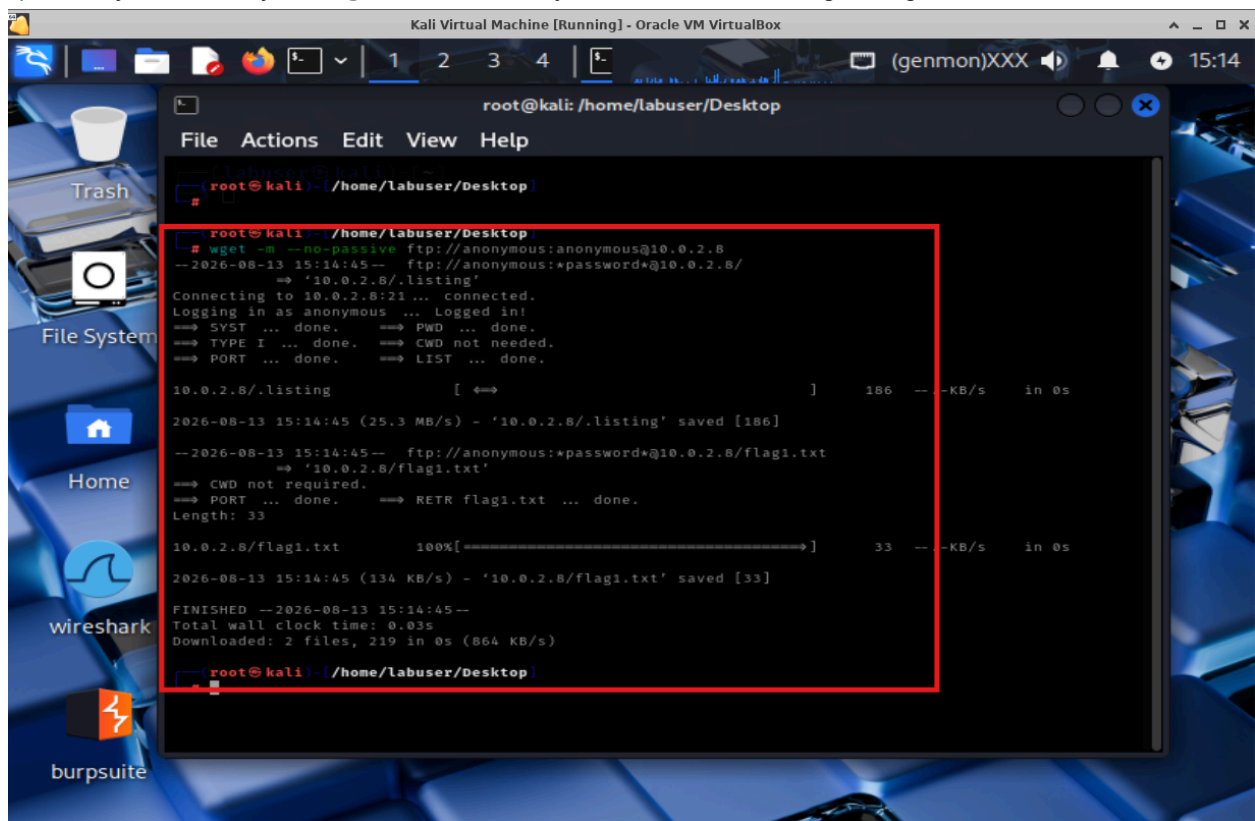
4.2 Now use command: "ls" we will see that it goes into passive mode.

A screenshot of a Kali Linux desktop environment running in Oracle VM VirtualBox. The desktop background is blue with icons for Trash, File System, Home, Wireshark, and Burpsuite. A terminal window titled 'root@kali: /home/labuser/Desktop' is open, showing an FTP session. The terminal output is as follows:

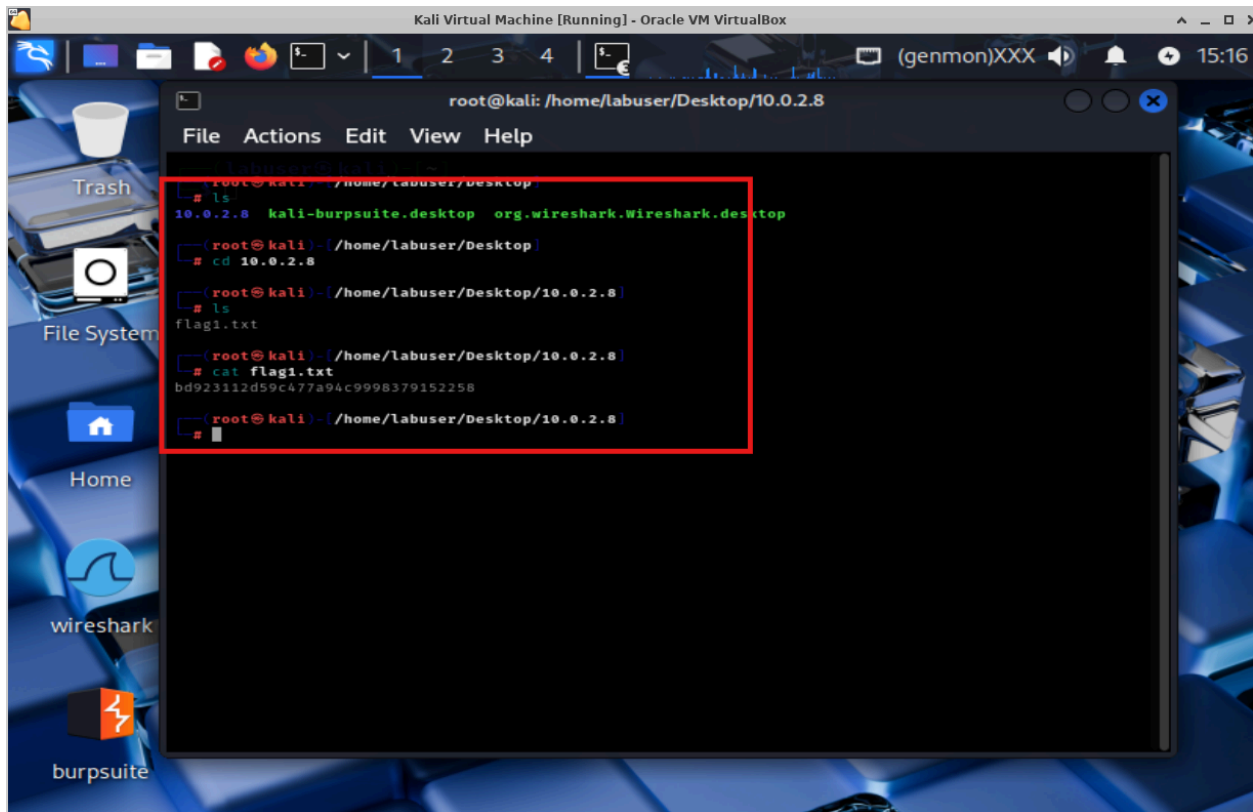
```
root@kali: /home/labuser/Desktop
File Actions Edit View Help
root@kali: /home/labuser/Desktop
# ftp 10.0.2.8
Connected to 10.0.2.8.
220 (vsFTPD 3.0.5)
Name (10.0.2.8:labuser): Anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||34810|)
```

The last two lines of the terminal output are highlighted with a red rectangle.

The screenshot shows a Kali Linux desktop environment. The desktop background is a blue-themed image. On the left side, there is a vertical dock with icons for 'Trash', 'File System', 'Home', 'wireshark', and 'burpsuite'. The top of the screen displays the system menu with various application icons and the system clock showing '15:14'. The terminal window is titled 'root@kali: /home/labuser/Desktop'. It shows a command being executed: `wget -m --no-passive ftp://anonymous:anonymous@10.0.2.8 -2026-08-13 15:14:45 -- ftp://anonymous:*password*@10.0.2.8/ -> '10.0.2.8/.listing'`. The output shows the file being downloaded at 186 KB/s. Then, another command is shown: `ftp://anonymous:*password*@10.0.2.8/flag1.txt -> '10.0.2.8/flag1.txt'`. The output shows the file being downloaded at 134 KB/s. The terminal window is highlighted with a red border.



4.4 Now in the terminal use command: "ls". Then you will see a directory appears. Then move into the directory then you will see the "flag1.txt" appears. Use command: "cat flag1.txt" to view the contents of the file. The value is: bd923112d59c477a94c9998379152258

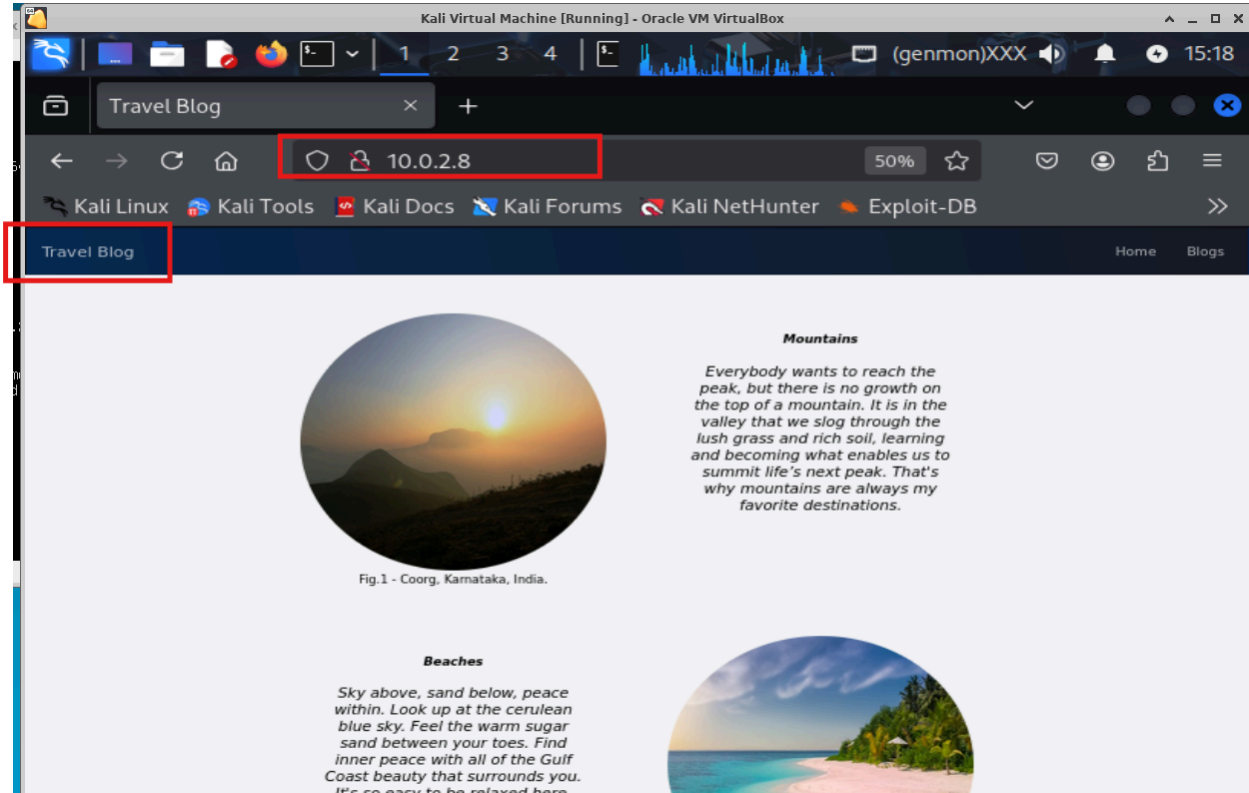


The screenshot shows a Kali Linux desktop environment with a terminal window open. The terminal window title is "root@kali: /home/labuser/Desktop/10.0.2.8". The terminal output is as follows:

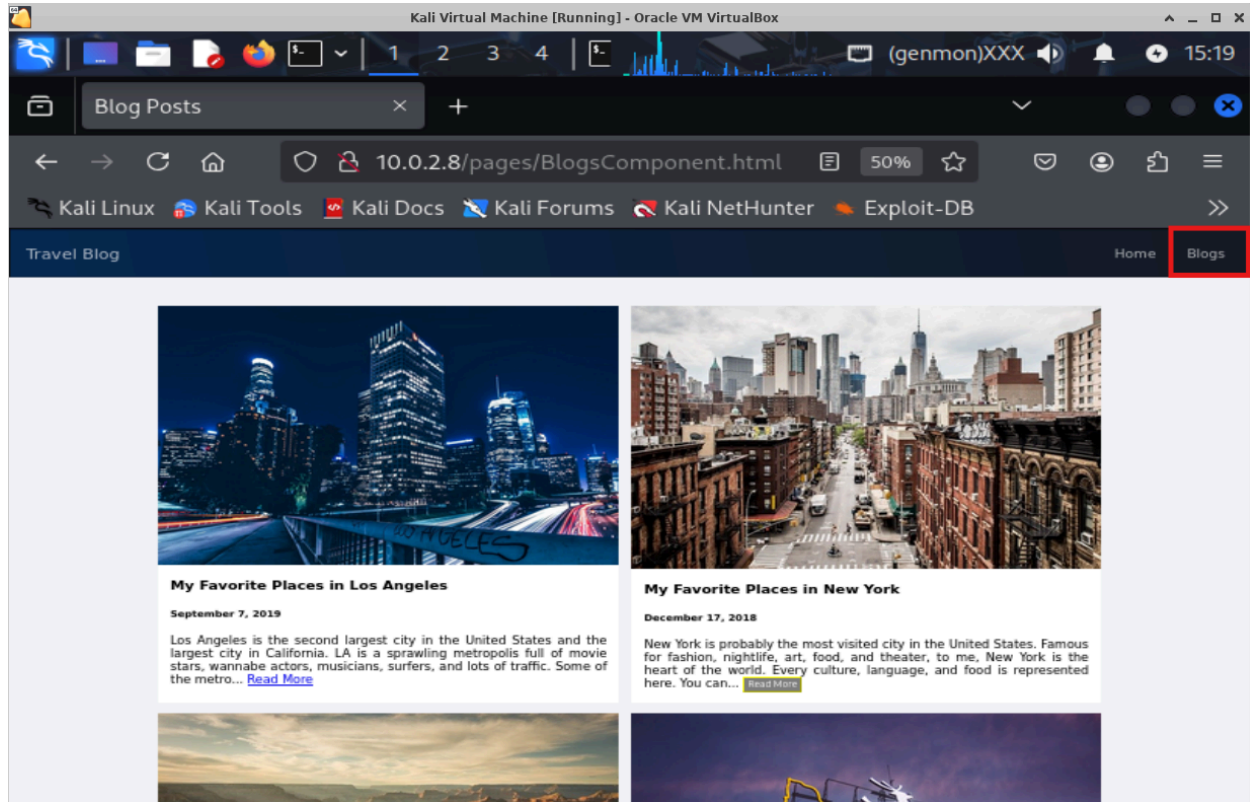
```
root@kali: /home/labuser/Desktop/10.0.2.8
# ls
10.0.2.8  kali-burpsuite.desktop  org.wireshark.Wireshark.desktop
# cd 10.0.2.8
# ls
flag1.txt
# cat flag1.txt
bd923112d59c477a94c9998379152258
#
```

The terminal window is titled "Kali Virtual Machine [Running] - Oracle VM VirtualBox". The desktop background is blue with icons for "Trash", "File System", "Home", "wireshark", and "burpsuite". The terminal window has a menu bar with "File", "Actions", "Edit", "View", and "Help".

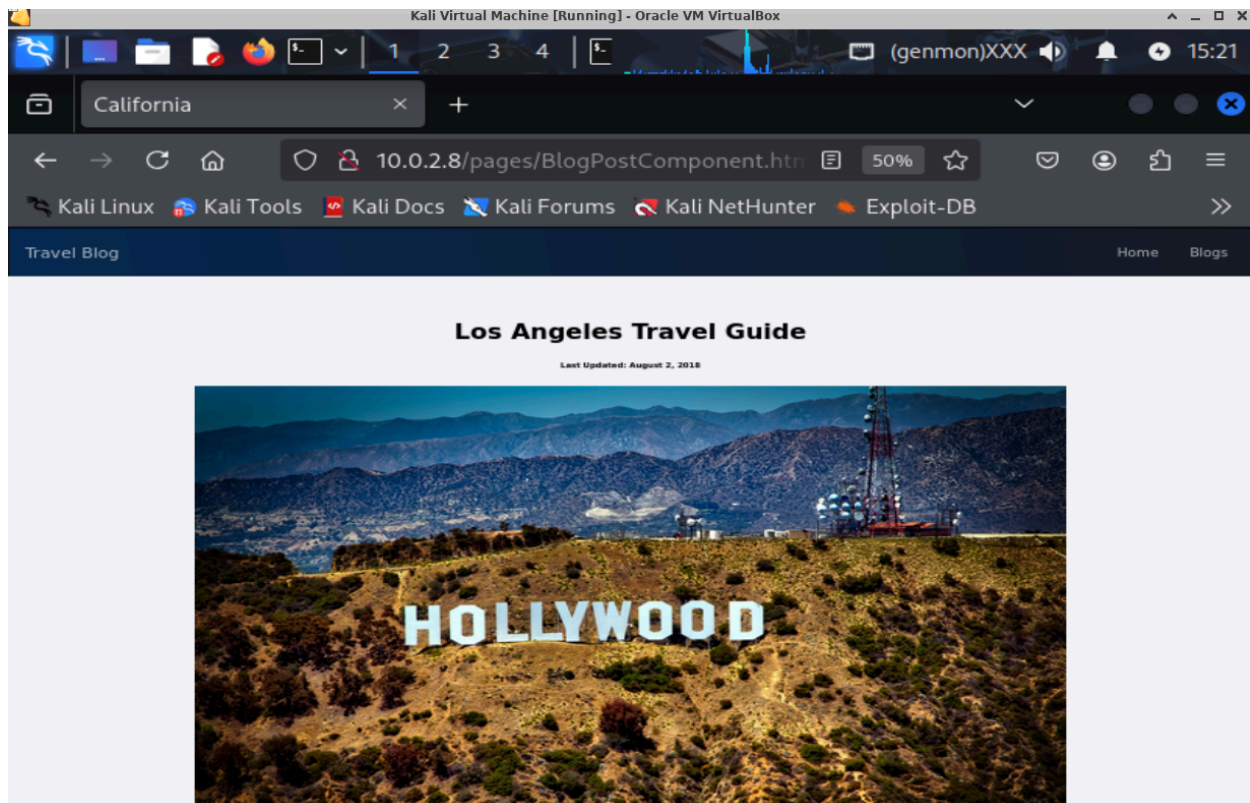
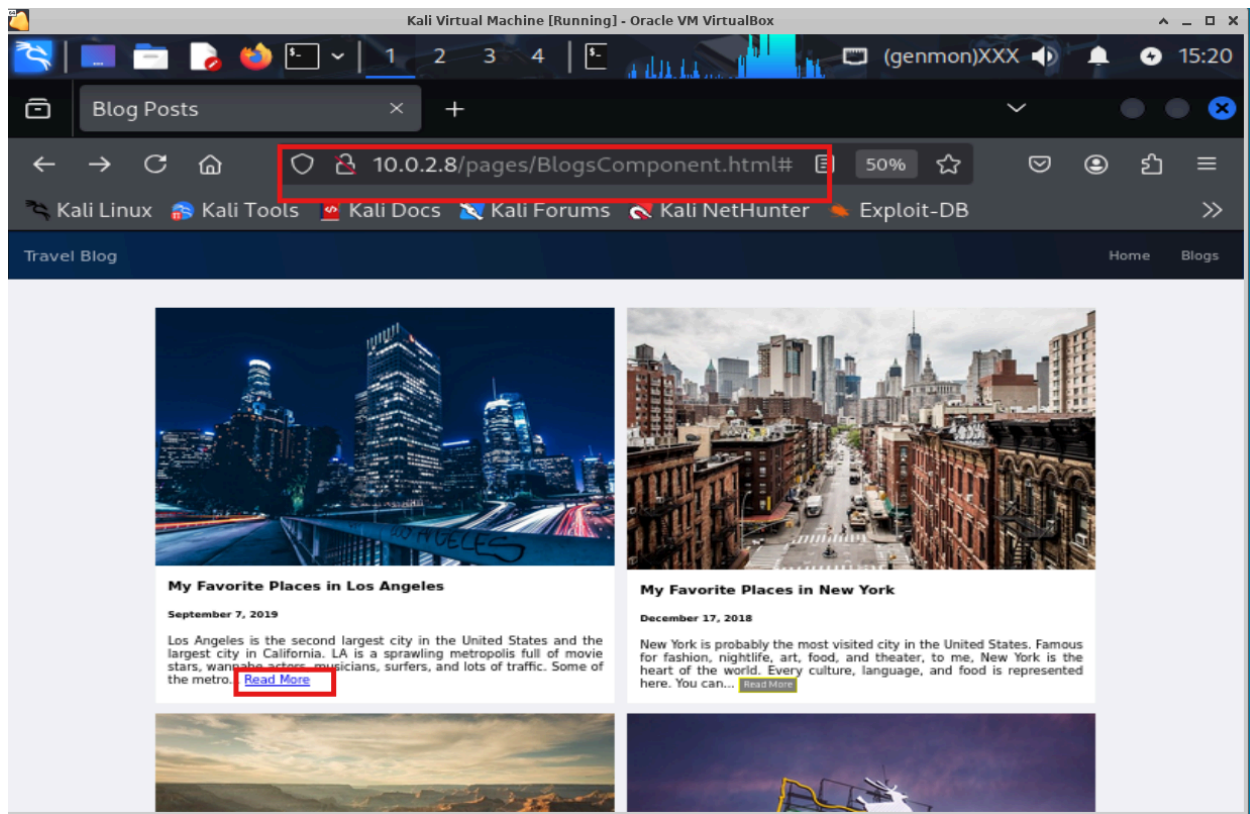
4.5 Now as we have http port open now let's see the website which the site is hosting. Open a web browser and search: "http://10.0.2.8". Then you will see the website appear. It represents a "Travel Blog"



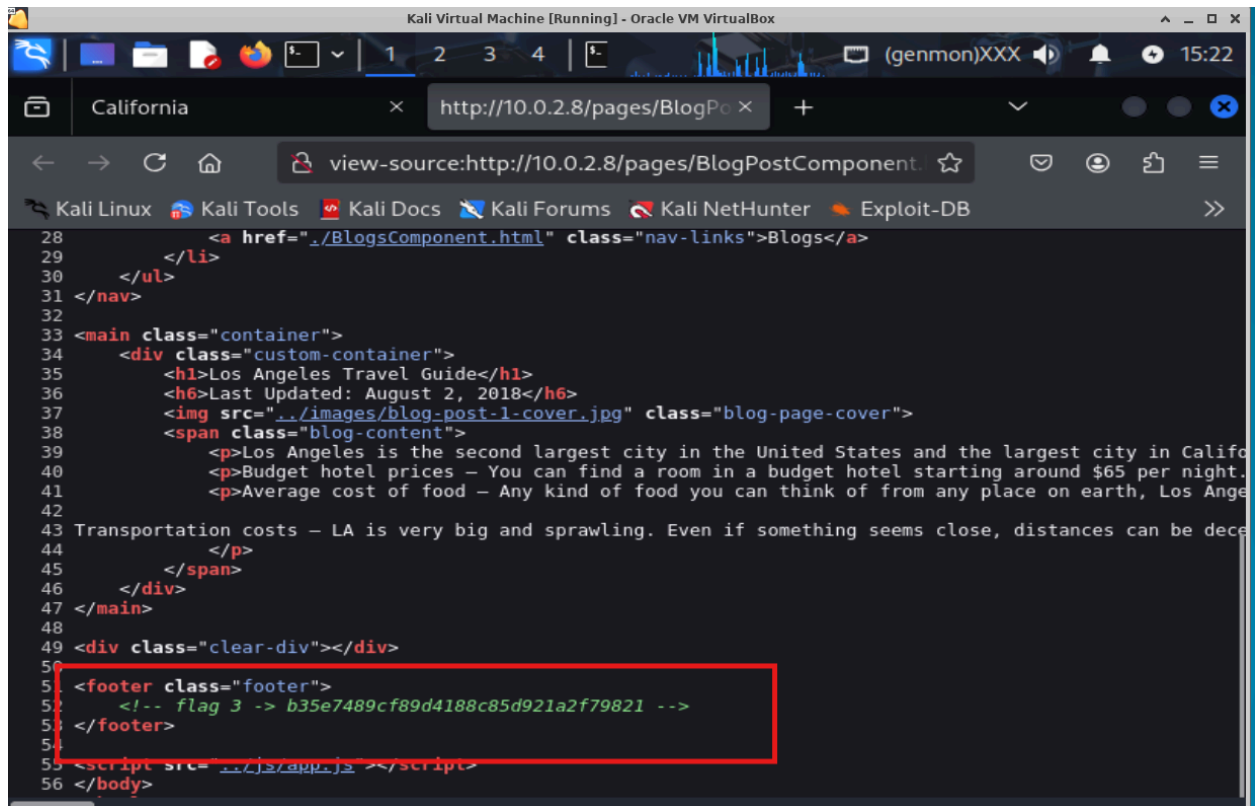
4.6 Now click on “Blogs”, which might not work so use the URL
<http://10.0.2.8/pages/BlogsComponent.html>



4.7 Click on Read More.



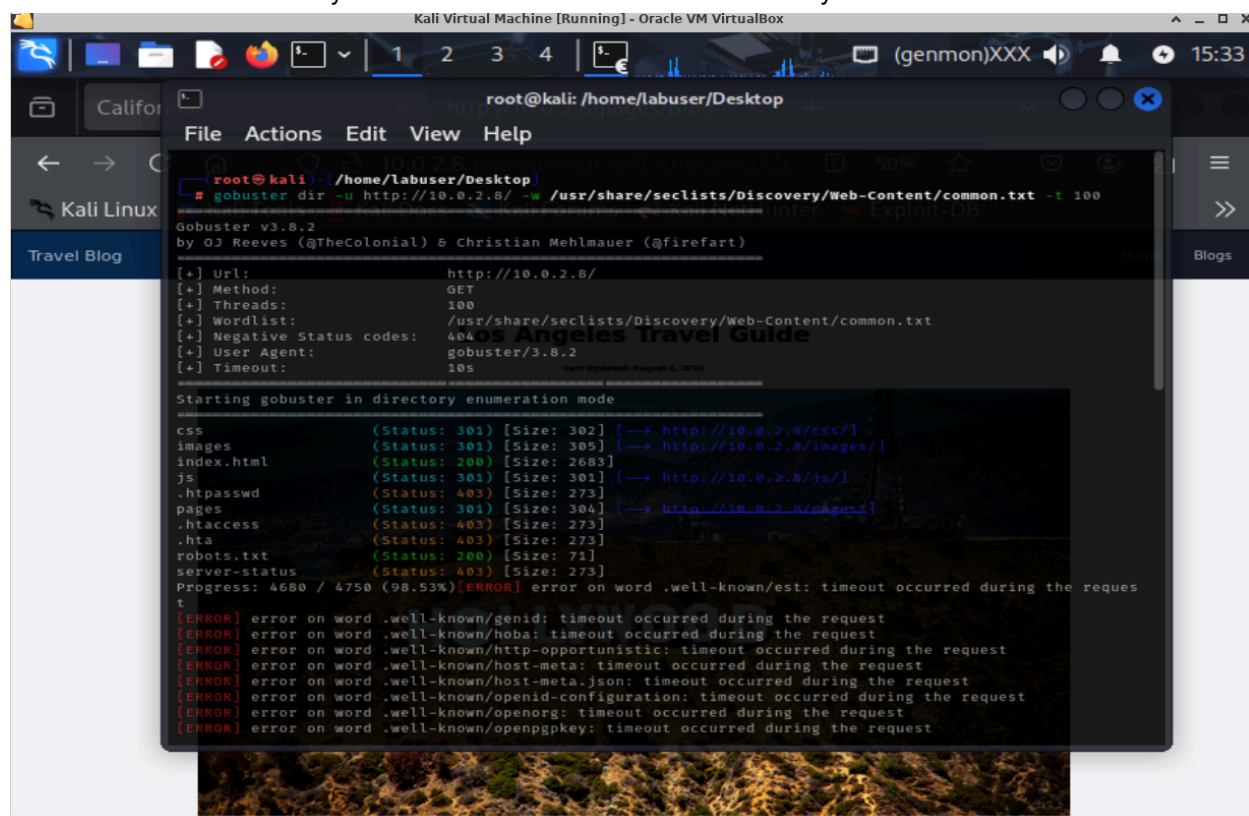
4.8 Now press “CTRL+U” to view the source of the website. Then you will see a flag present.



```
28 <a href="._/BlogsComponent.html" class="nav-links">Blogs</a>
29 </li>
30 </ul>
31 </nav>
32
33 <main class="container">
34 <div class="custom-container">
35 <h1>Los Angeles Travel Guide</h1>
36 <h6>Last Updated: August 2, 2018</h6>
37 
38 <span class="blog-content">
39 <p>Los Angeles is the second largest city in the United States and the largest city in Califo
40 <p>Budget hotel prices – You can find a room in a budget hotel starting around $65 per night.
41 <p>Average cost of food – Any kind of food you can think of from any place on earth, Los Ange
42
43 Transportation costs – LA is very big and sprawling. Even if something seems close, distances can be dece
44 </p>
45 </span>
46 </div>
47 </main>
48
49 <div class="clear-div"></div>
50
51 <footer class="footer">
52 <!-- flag 3 -> b35e7489cf89d4188c85d921a2f79821 -->
53 </footer>
54
55 <script src="._/c.js/app.js"></script>
56 </body>
```

4.9 The value of the flag is: “flag 3 -> b35e7489cf89d4188c85d921a2f79821”

4.10 Now we will perform directory bursting. Use command: "gobuster dir -u http://10.0.2.8/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 100". Then you will find some directories.



The screenshot shows a Kali Linux terminal window titled "Kali Virtual Machine [Running] - Oracle VM VirtualBox". The terminal is running the command: `gobuster dir -u http://10.0.2.8/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 100`. The output shows the command's configuration and the results of the directory enumeration.

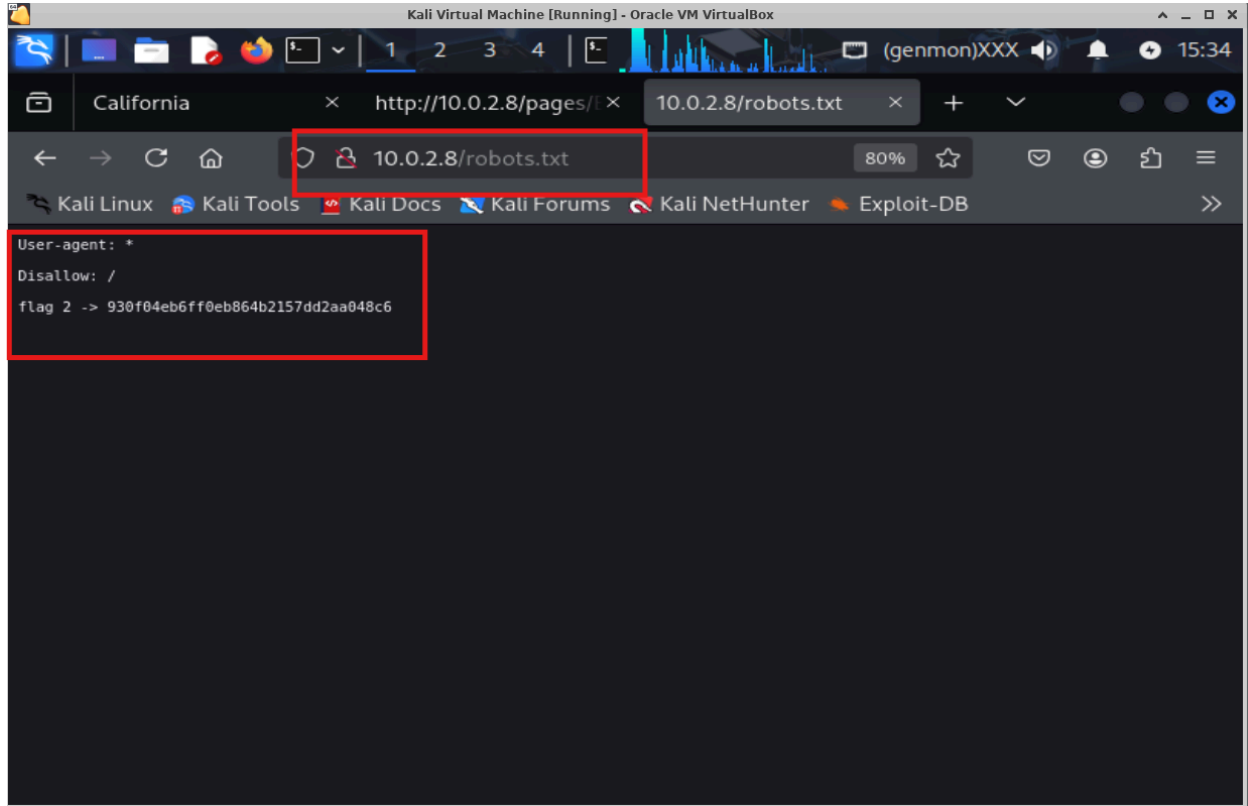
```
gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.0.2.8/
[+] Method: GET
[+] Threads: 100
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

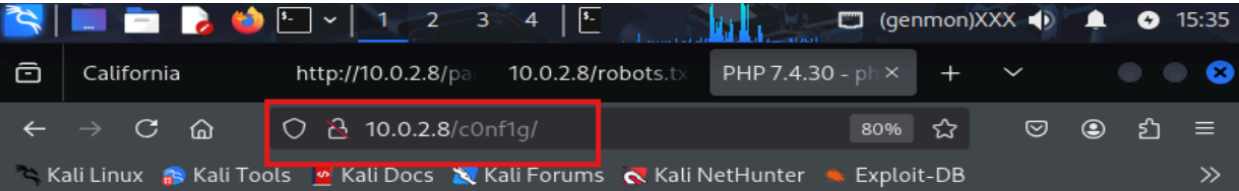
Starting gobuster in directory enumeration mode

css (Status: 301) [Size: 302] [→ http://10.0.2.8/css/]
images (Status: 301) [Size: 305] [→ http://10.0.2.8/images/]
index.html (Status: 200) [Size: 2683]
js (Status: 301) [Size: 301] [→ http://10.0.2.8/js/]
.htpasswd (Status: 403) [Size: 273]
pages (Status: 301) [Size: 304] [→ http://10.0.2.8/pages/]
.htaccess (Status: 403) [Size: 273]
.hta (Status: 403) [Size: 273]
robots.txt (Status: 200) [Size: 71]
server-status (Status: 403) [Size: 273]
Progress: 4680 / 4750 (98.53%) [ERROR] error on word .well-known/est: timeout occurred during the request
[ERROR] error on word .well-known/genid: timeout occurred during the request
[ERROR] error on word .well-known/hoba: timeout occurred during the request
[ERROR] error on word .well-known/http-opportunistic: timeout occurred during the request
[ERROR] error on word .well-known/host-meta: timeout occurred during the request
[ERROR] error on word .well-known/host-meta.json: timeout occurred during the request
[ERROR] error on word .well-known/openid-configuration: timeout occurred during the request
[ERROR] error on word .well-known/openorg: timeout occurred during the request
[ERROR] error on word .well-known/openpgpkey: timeout occurred during the request
```

4.11 Now navigate to the website: "http://10.0.2.8/robots.txt". Then you will see a flag appear. The Value is: flag 2 -> 930f04eb6ff0eb864b2157dd2aa048c6



4.12 Now browse the website: "http://10.0.2.8/c0nf1g/" then you will see the following flag appear. The value is: flag 5 -> 88615e277ae89ad96a4a365a9a854740



California http://10.0.2.8/pa 10.0.2.8/robots.txt PHP 7.4.30 - ph x

← → ↻ 🏠 🔒 10.0.2.8/c0nf1g/ 80% ☆ 📧 👤 ⌵

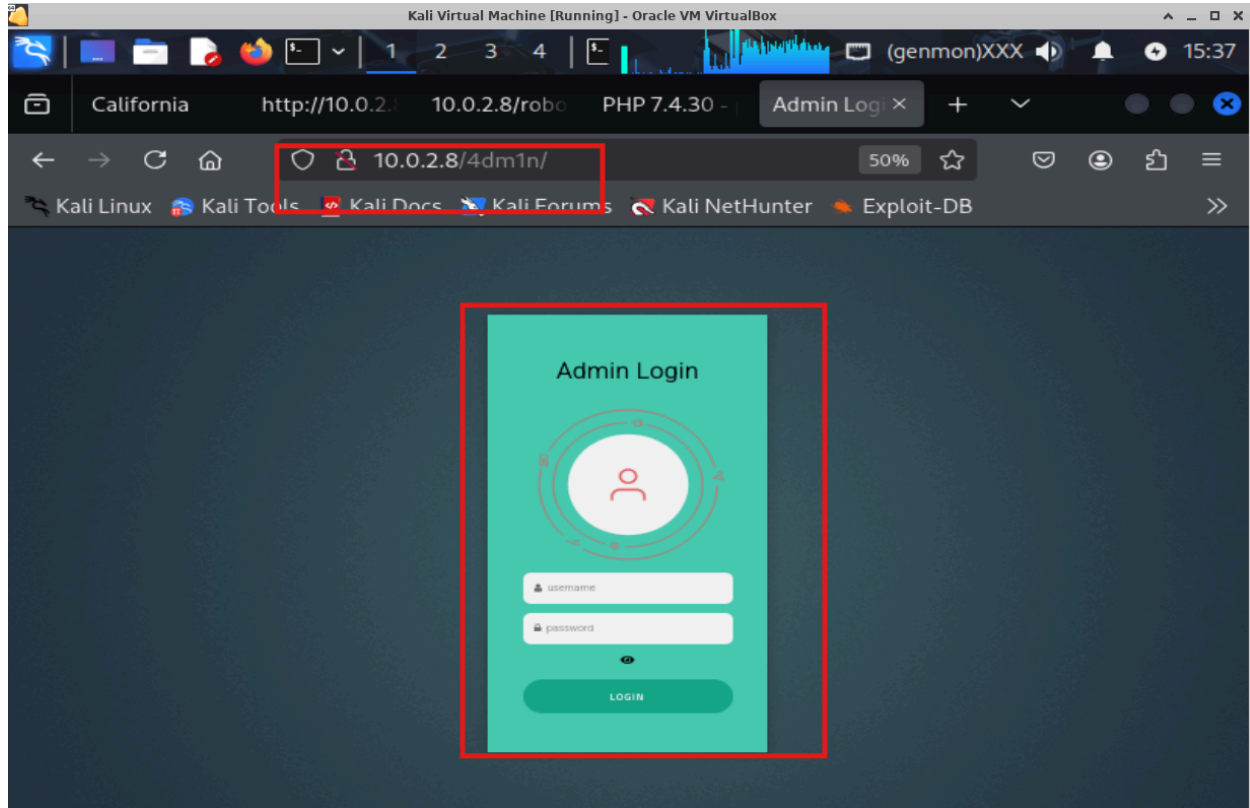
Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB >>

flag 5 -> 88615e277ae89ad96a4a365a9a854740

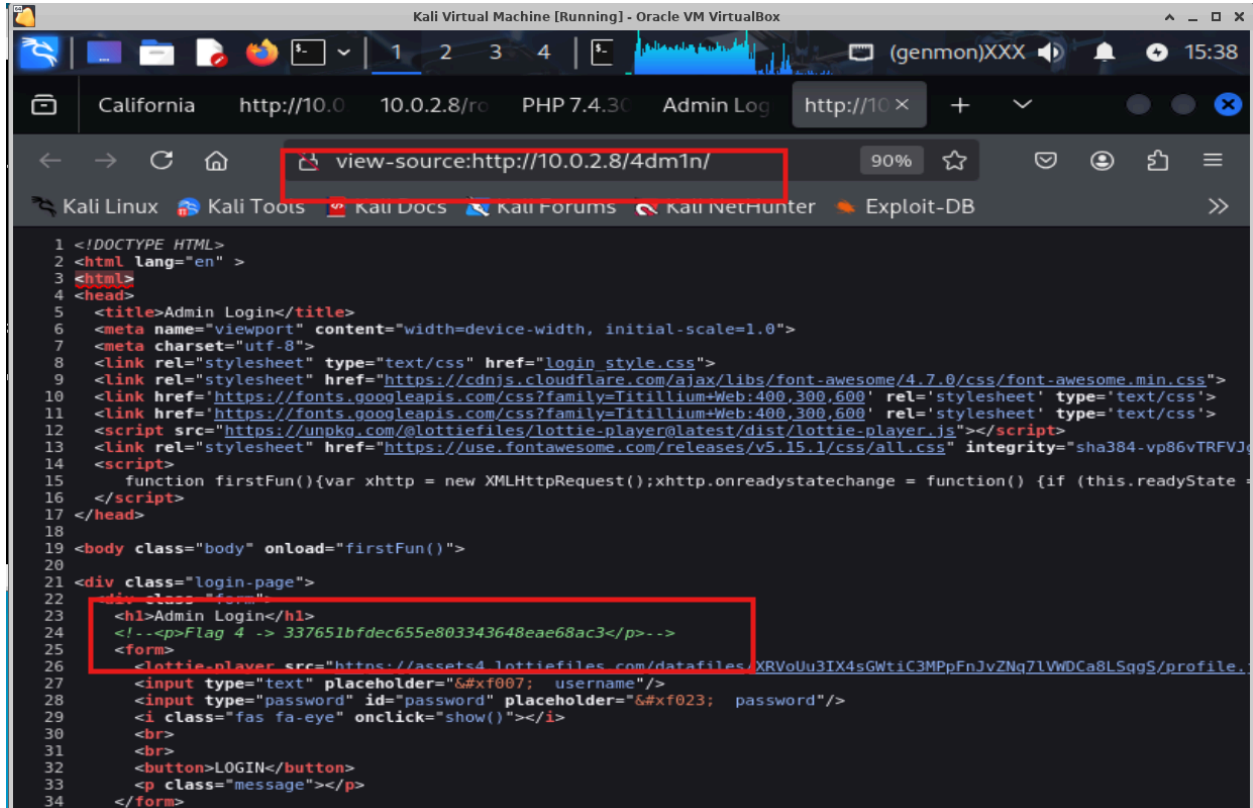
PHP Version 7.4.30 

System	Linux vulnvm 5.15.0-47-generic #51-Ubuntu SMP Thu Aug 11 07:51:15 UTC 2022 x86_64
Build Date	Aug 1 2022 15:06:35
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php/7.4/apache2
Loaded Configuration File	/etc/php/7.4/apache2/php.ini
Scan this dir for additional .ini files	/etc/php/7.4/apache2/conf.d
Additional .ini files parsed	/etc/php/7.4/apache2/conf.d/10-opcache.ini, /etc/php/7.4/apache2/conf.d/10-pdo.ini, /etc/php/7.4/apache2/conf.d/20-calendar.ini, /etc/php/7.4/apache2/conf.d/20-ctype.ini, /etc/php/7.4/apache2/conf.d/20-exif.ini, /etc/php/7.4/apache2/conf.d/20-ffi.ini, /etc/php/7.4/apache2/conf.d/20-fileinfo.ini, /etc/php/7.4/apache2/conf.d/20-ftp.ini, /etc/php/7.4/apache2/conf.d/20-gettext.ini, /etc/php/7.4/apache2/conf.d/20-iconv.ini, /etc/php/7.4/apache2/conf.d/20-json.ini, /etc/php/7.4/apache2/conf.d/20-phar.ini, /etc/php/7.4/apache2/conf.d/20-posix.ini, /etc/php/7.4/apache2/conf.d/20-readline.ini, /etc/php/7.4/apache2/conf.d/20-shmop.ini, /etc/php/7.4/apache2/conf.d/20-sockets.ini, /etc/php/7.4/apache2/conf.d/20-sysvmsg.ini, /etc/php/7.4/apache2/conf.d/20-sysvsem.ini, /etc/php/7.4/apache2/conf.d/20-sysvshm.ini, /etc/php/7.4/apache2/conf.d/20-tokenizer.ini
PHP API	20190902
PHP Extension	20190902
Zend Extension	320190902
Zend Extension Build	API320190902.NTS

4.13 Now navigate to the website: “http://10.0.2.8/4dm1n/”. Then you will see the following log in page appears.

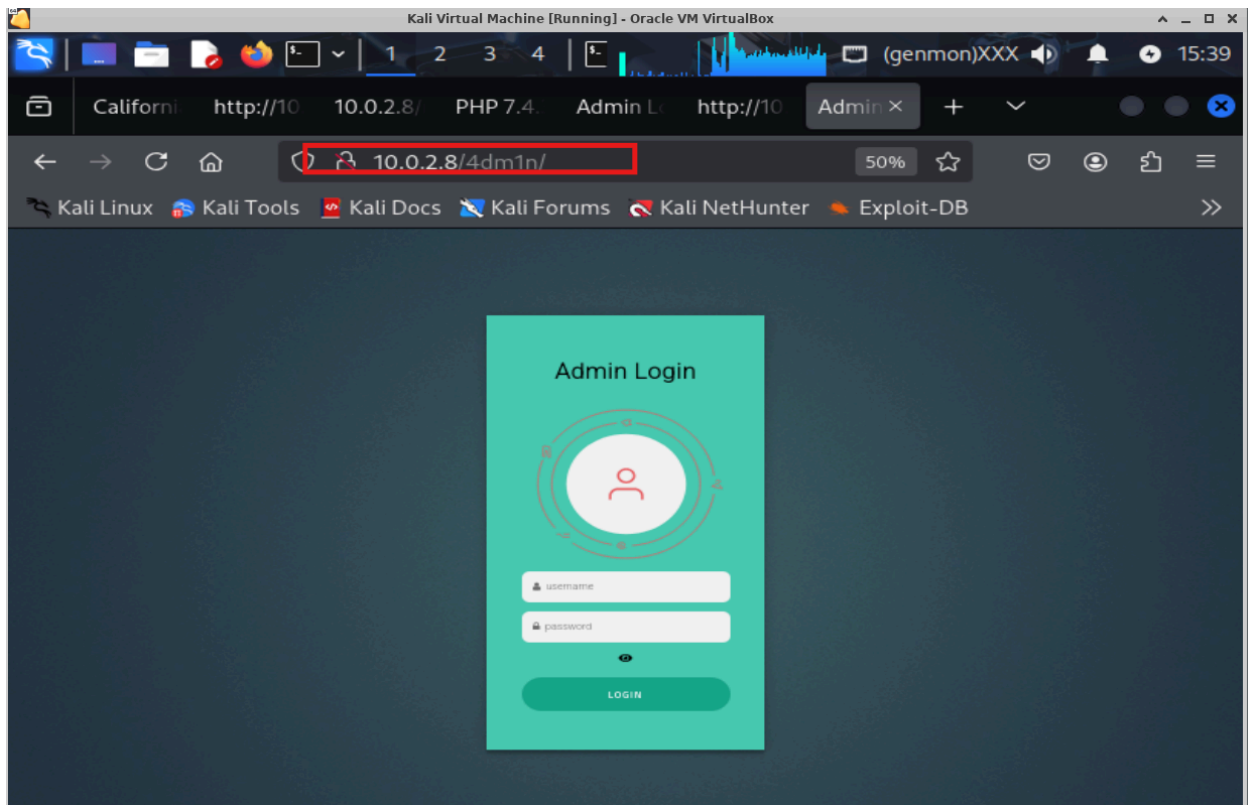


4.14 Now press "CTRL+U" to view the source of the website. Then you will see the flag appear. Flag 4 -> 337651bfdec655e803343648eae68ac3

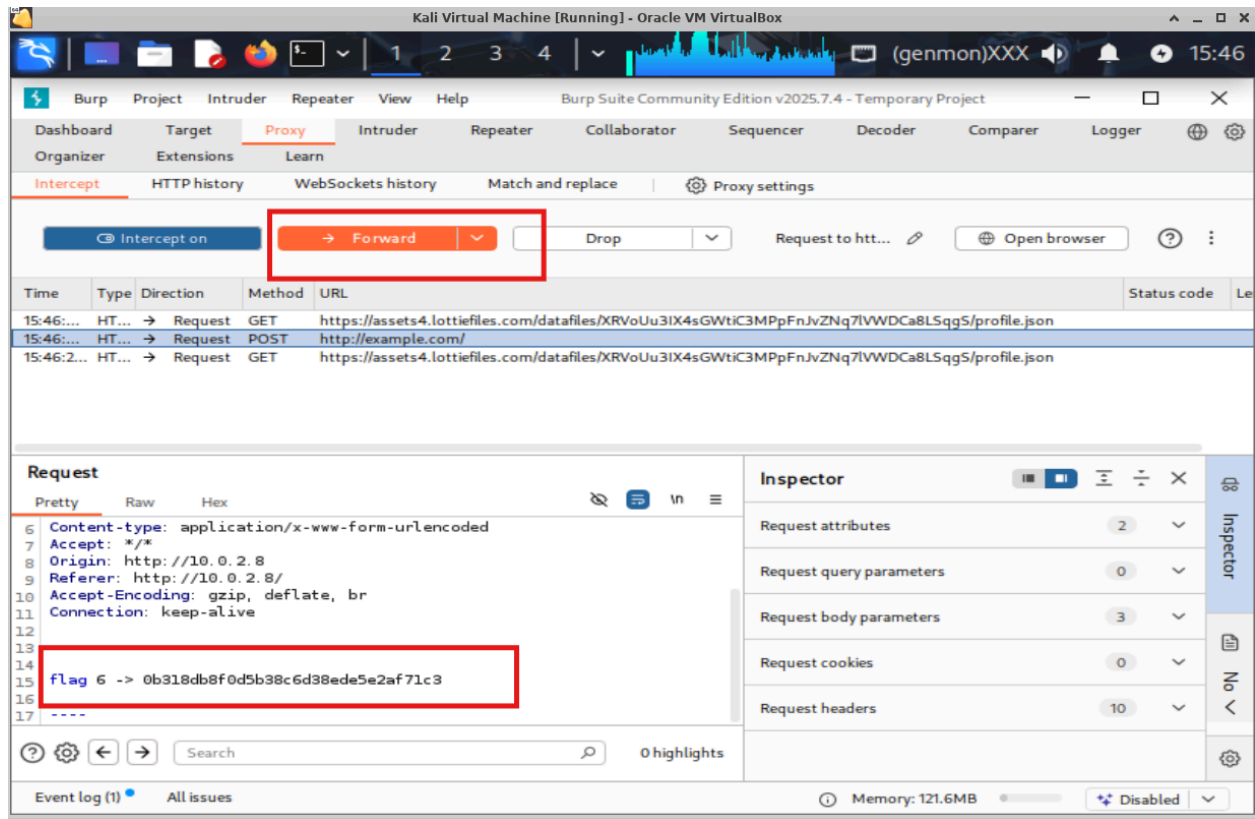


```
1 <!DOCTYPE HTML>
2 <html lang="en" >
3 <html>
4 <head>
5   <title>Admin Login</title>
6   <meta name="viewport" content="width=device-width, initial-scale=1.0">
7   <meta charset="utf-8">
8   <link rel="stylesheet" type="text/css" href="login_style.css">
9   <link rel="stylesheet" href="https://cdnjs.cloudflare.com/ajax/libs/font-awesome/4.7.0/css/font-awesome.min.css">
10  <link href="https://fonts.googleapis.com/css?family=Titillium+Web:400,300,600" rel="stylesheet" type="text/css">
11  <link href="https://fonts.googleapis.com/css?family=Titillium+Web:400,300,600" rel="stylesheet" type="text/css">
12  <script src="https://unpkg.com/lottiefiles/lottie-player@latest/dist/lottie-player.js"></script>
13  <link rel="stylesheet" href="https://use.fontawesome.com/releases/v5.15.1/css/all.css" integrity="sha384-vp86vTRFVJ"
14  <script>
15    function firstFun(){var xhttp = new XMLHttpRequest();xhttp.onreadystatechange = function() {if (this.readyState ==
16  </script>
17 </head>
18
19 <body class="body" onload="firstFun()">
20
21 <div class="login-page">
22   <div class="form">
23     <h1>Admin Login</h1>
24     <!--<p>Flag 4 -> 337651bfdec655e803343648eae68ac3</p-->
25     <form>
26       <lottie-player src="https://assets4.lottiefiles.com/datafiles/XRVouU3IX4sGWtiC3MPpFnJvZNq7lVwDCa8LSqgS/profile."
27       <input type="text" placeholder="#xf007; username"/>
28       <input type="password" id="password" placeholder="#xf023; password"/>
29       <i class="fas fa-eye" onclick="show()"></i>
30       <br>
31       <br>
32       <button>LOGIN</button>
33       <p class="message"></p>
34     </form>
```

4.15 Now open the website “http://10.0.2.8/4dm1n/”. Then make sure you have already set up Burpsuite.



4.16 Refresh the page using the “Reload” Symbol. Make sure the intercept is on. Then click on “Forward”. Then you will see the flag appear as shown in the screenshot.



4.17 The value is: flag 6 -> 0b318db8f0d5b38c6d38ede5e2af71c3

Task 5: Reporting

Report on Vulnerabilities in the Application

Target Application: Travel Blog (IP: 10.0.2.8)

Objective: Identify security weaknesses through penetration testing.

Findings and Recommendations

Open Ports and FTP Misconfigurations

- **Vulnerability:** FTP service allowed anonymous login.
- **Exploitation:** Anonymous access enabled downloading of sensitive files (e.g., flag1.txt).
- **Recommendation:** Disable anonymous FTP access and enforce robust authentication measures.

Sensitive Data Exposure in Website Source Code

- **Vulnerability:** Sensitive information was exposed in the HTML source code.
- **Exploitation:** Flags were visible, such as "flag3 -> b35e7489cf89d4188c85d921a2f79821".
- **Recommendation:** Avoid embedding sensitive data in source code. Secure web development practices are essential.

Insecure File Access

- **Vulnerability:** Misplaced files and directories (e.g., /robots.txt, /c0nf1g/) exposed sensitive information.
- **Exploitation:** Tools like gobuster revealed accessible directories, exposing flags like "flag2 -> 930f04eb6ff0eb864b2157dd2aa048c6".
- **Recommendation:** Implement robust access control and secure sensitive files against unauthorized access.

Weak Access Control in Admin Panel

- **Vulnerability:** Admin panel (/4dm1n/) lacked proper security controls.
- **Exploitation:** Sensitive information like "flag4 -> 337651bfdec655e803343648eae68ac3" was accessible, and Burp Suite allowed further flag retrieval.
- **Recommendation:** Use multi-factor authentication (MFA) and restrict access to sensitive application sections.

Misconfigured Web Application and Directory Listing

- **Vulnerability:** Directory listing enabled attackers to identify and access sensitive files.
- **Exploitation:** Tools revealed sensitive directories, compromising configuration files.
- **Recommendation:** Disable directory listing and restrict public access to unnecessary directories.

Conclusion

The assessment identified multiple critical vulnerabilities, including FTP misconfigurations, exposed sensitive data, and weak access control. Exploitation of these weaknesses could lead to unauthorized access and compromise of the application.

Recommended Actions

Security Configuration:

Disable anonymous FTP access and enforce strong authentication.
Use .htaccess or server configurations to block sensitive files.

Web Application Security:

Avoid embedding sensitive data in HTML source code. Implement secure coding practices.

Regular Audits and Updates:

Conduct frequent security audits. Regularly update the server and application to patch vulnerabilities.

Developer Training:

Educate developers on secure coding and configuration practices.